A Study on

Multi-Party Consent Management System

A thesis submitted in fulfilment of the requirements for the degree of

Doctor of Philosophy

in

Computer Science

by

Yasir Dhaifallah O Alyoubi

Supervisor: Professor Farookh Hussain

Co-supervisor: Dr Firas Al-Doghman

School of Computer Science

Faculty of Engineering and Information Technology

University of Technology Sydney

NSW, Australia

July 2027

CERTIFICATE OF ORIGINAL AUTHORSHIP

I, Yasir Dhaifallah O Alyoubi, declare that this thesis, submitted in fulfilment of the requirements for the award of Doctor of Philosophy, in the School of Computer Science, Faculty of Engineering and Information Technology at the University of Technology Sydney, Australia, is wholly my own work unless otherwise referenced or acknowledged. In addition, I certify that all information sources and literature used are indicated in the thesis. This document has not been submitted for qualifications at any other academic institution. This research is supported by the Australian Government Research Training Program.

Signature of Candidate: Yasir Dhaifallah O Alyoubi

Date:

DEDICATION

To my family

ACKNOWLEDGMENTS

All praise is due to Allah, Lord of the worlds, who gave me the strength, the patience and the means to reach this point. Every step of this journey was by His grace, and I thank Him first and last.

A thesis is never the work of one person, and when it is finished it is right to look back and thank those who made it possible. My deepest gratitude goes to my supervisor, Professor Farookh Hussain. He accepted me as his student, guided my research from its first idea to its last chapter, corrected me with patience when I was wrong, and encouraged me when I doubted myself. He was more than a supervisor to me; he was a mentor and an elder brother, and his door was always open. Without his support I could not have completed this work.

I also thank my co-supervisor, Dr Firas Al-Doghman, for his guidance, his careful reading of my work and his advice at every stage of this research.

I thank the University of Technology Sydney for giving me the opportunity to study here, for the scholarship that made this research possible, and for the environment, the resources and the people that made it a second home.

Finally, I thank my family. My parents, whose prayers and sacrifices have been with me all my life. My wife, who stood beside me through every long day and night of this journey and carried more than her share so that I could study. My children, who gave me the reason to keep going. And my brothers and sisters, whose support never failed. This thesis is for all of them.

PUBLICATIONS

Conference publications

1- 'A Blockchain-Based Framework for Evaluating User Identity Trustworthiness in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

2- 'Blockchain-Based Reputation Borrowing Model to Address the Cold Start Problem for New Users in Real Estate', 2025 IEEE International Conference on E-Business Engineering (ICEBE), 2025. (Published)

3- 'A Smart Contract-Governed Lifecycle Protocol for Reputation Borrowing in Blockchain-Based Real Estate Platforms', ICEBE 2026. (Accepted)

4- 'A Trusted Multi-Party Consent Governance Framework for Decentralized Multi-Stakeholder Data Sharing', BWCCA 2026. (Accepted)

5- 'Blockchain-Based Reputation Provenance Tracing for Newcomer Bootstrapping in Real Estate', BWCCA 2026. (Accepted)

TABLE OF CONTENTS

Certificate of Original Authorship ..... **i**

Dedication ..... **ii**

Acknowledgments ..... **iii**

Publications ..... **iv**

Table of Contents ..... **v**

List of Figures ..... **ix**

List of Tables ..... **x**

Abstract ..... **xi**

1 Introduction **1**

1.1 Introduction 1
1.2 Statement of the Problem 2
1.3 Research Motivation 2
1.4 Decentralised Identity Technology 3
1.4.1 Decentralised Identifiers (DIDs) 4
1.4.2 Verifiable Credentials (VCs) 4
1.4.3 Trusted Issuers and Credential Verification 4
1.5 Multi-Party Authorisation 4
1.6 The Relationship between Multi-Party Authorisation and Patient Consent 5
1.7 Purpose of Using Multi-Party Authorisation in Consent Management 5
1.8 Authorisation Evidence and Auditability 5
1.8.1 The Audit Ledger 6
1.9 Consent Management Systems 6
1.10 Challenges Faced by Current Consent Management Systems 6
1.11 Research Contribution 6
1.11.1 Scientific Contribution 6
1.11.2 Social Contribution 7
1.12 Thesis Plan 7
1.13 Conclusion 7

2 A Systematic Literature Review **9**

2.1 Introduction 9
2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation 9
2.2.1 Req 1: Representation of consent as an evaluable authorisation object. 10
2.2.2 Req 2: Decentralised verification of identity and authority 10
2.2.3 Req 3: Multi-party authorisation through a verifiable threshold 10
2.2.4 Req 4: Policy- and context-aware enforcement at the time of access. 10
2.2.5 Req 5: Temporal validity and lifecycle control of consent 10
2.2.6 Req 6: Verifiable auditability and security assurance 10
2.3 Process Adopted for Shortlisting the Papers for SLR 11

2.3.1 Step 1: Criteria for Searching the Literature....11
2.3.2 Step 2: Inclusion and Exclusion Criteria....12
2.3.3 Step 3: Quality Evaluation....13
2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas....14
2.4 Summary of Papers Shortlisted in the SLR....15
2.4.1 Consent representation and blockchain-based consent governance (Req 1)....15
2.4.2 Decentralised identity and authority trust (Req 2)....16
2.4.3 Multi-party authorisation and collaborative consent (Req 3)....16
2.4.4 Policy- and context-aware access control (Req 4)....18
2.4.5 Temporal validity and consent lifecycle (Req 5)....19
2.4.6 Formal security assurance and empirical validation (Req 6)....19
2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective....20
2.5 Trust-Oriented Multi-Party Consent Authorisation Framework....24
2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)....25
2.5.2 Decentralised Verification of Identity and Authority (Req 2)....25
2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)....25
2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4)....25
2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)....25
2.5.6 Verifiable Auditability and Security Assurance (Req 6)....25
2.6 Conclusion....25

3 Research Questions and Objectives....27

3.1 Introduction....27
3.2 Gaps in the Literature....27
3.3 Key Definitions....28
3.4 Research Questions....28
3.4.1 Research Questions as an Integrated Problem....29
3.5 Research Objectives....29
3.5.1 RO1: Trust-Centric Consent Model....29
3.5.2 RO2: Decentralised Identity and Authority Trust....30
3.5.3 RO3: Trustworthy Multi-Party Authorisation....30
3.5.4 RO4: Policy- and Context-Aware Access Control....30
3.5.5 RO5: Temporal and Lifecycle Trust....30
3.5.6 RO6: Formal Security Assurance and Empirical Validation....31
3.5.7 Relationship Between Research Questions and Objectives....31
3.6 Conclusion....32

4 Research Methodology and Solution Overview....33

4.1 Introduction....33
4.2 Key Definitions....33
4.3 Selected Research Methodology....34
4.4 Solution Overview....34
4.5 Overview of Solution for RQ1....36
4.6 Overview of Solution for RQ2....37

4.7 Overview of Solution for RQ3....37
4.8 Overview of Solution for RQ4....37
4.9 Overview of Solution for RQ5....38
4.10 Overview of Solution for RQ6....38
4.10.1 Testing and Verification of the Solution....38
4.11 Conclusion....38

5 Research Architecture and Trust-Centric Consent Model....40

5.1 Introduction....40
5.2 Layered Architecture and Component Decomposition....41
5.3 Trust Evaluation and Architectural Boundaries....43
5.4 MVC Architecture and the Research Objectives....45
5.5 Trust-Centric Consent Model....47
5.5.1 Consent Creation Workflow....47
5.5.2 Structure of the Consent Object....48
5.5.3 Trust-Aware Consent Creation Procedure and Algorithm....49
5.6 Prototype Implementation....51
5.6.1 Aims of Engineering the Prototype System....51
5.7 Datasets Used for Validation....52
5.8 Steps in the Working of the Prototype System for Consent Creation....52
5.8.1 Steps in the patient interface....53
5.8.2 Steps in the service layer....53
5.9 Prototype Evaluation and Discussion....54
5.9.1 Validation of Consent Creation....54
5.9.2 Evaluation of the Architecture against the Security Properties....56
5.9.3 Discussion....57
5.10 Conclusion....57

6 Decentralised Identity and Authority Trust....59

6.1 Introduction....59
6.2 Decentralised Identifiers and Verifiable Credentials....59
6.2.1 Decentralised Identifiers....60
6.2.2 Verifiable Credentials....60
6.2.3 Credential Store and Trusted Issuers....61
6.3 Overview of Decentralised Identity and Authority Trust....61
6.4 Identity and Authority Verification Workflow....62
6.5 Verification Model and Algorithm....63
6.5.1 Step-by-Step Procedure for DID and VC Identity and Authority Verification....63
6.5.2 Algorithm 2: DID and VC Identity and Authority Verification....64
6.6 Prototype Implementation....65
6.6.1 Realisation in the Prototype....65
6.6.2 Steps in the Working of the Prototype for Identity and Authority Verification....66
6.7 Prototype Validation and Discussion....67
6.7.1 Validation of Identity and Authority Verification....67
6.7.2 Discussion....69
6.8 Conclusion....70

LIST OF FIGURES

2.1 PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages..... 13
2.2 Synthesis of the review: the conjunction gap and the assurance gap addressed by the proposed framework, with the number of the 25 analysed studies graded Yes for each requirement in Table 2.10.....23
4.1 The Design Science Research process of this thesis, with the output of each stage, adapted from Peffers et al. (2007).....34
4.2 End-to-end workflow of the trust-oriented consent authorisation framework. 35
5.1 Layered MVC architecture and component decomposition of the HALAH framework..... 41
5.2 Functional decomposition of the MVC components.....42
5.3 Trust predicate evaluation and authorisation decision flow.....44
5.4 The four gates that an access request passes before data are released.....45
5.5 RO1 workflow for trust-centric consent creation.....48
5.6 Six-component consent model C = (I, A, P, T, L, E).....49
5.7 The patient interface of the HALAH prototype after a consent has been created. 53
5.8 A specification that names the same guardian twice is rejected by Algorithm 1 before any consent is stored.....55
6.1 Structure of a decentralised identifier and its DID document (after W3C 2022) 60
6.2 Structure of the role credential used by the prototype.....61
6.3 RO2 workflow for decentralised identity and authority verification.....62
6.4 Steps of the prototype for verifying the identity and the authority of a participant..... 66
6.5 Guardian interface after the credential of did:parent:A has been verified and the approval signed.....67
6.6 Doctor interface for a requester with a valid credential who is not the doctor named in the consent..... 67

LIST OF TABLES

2.1 Databases searched and records retrieved.....11
2.2 Summary of the stages of evaluating and selecting the relevant papers for the SLR.....12
2.3 Listing of the 25 primary studies identified after the selection process.....14
2.4 Descriptions, issues and limitations of the studies on consent representation..15
2.5 Descriptions, issues and limitations of the studies on identity and authority…16
2.6 Descriptions, issues and limitations of the studies on multi-party authorisation 17
2.7 Descriptions, issues and limitations of the studies on policy and context.....18
2.8 Descriptions, issues and limitations of the studies on temporal validity and lifecycle.....19
2.9 Descriptions, issues and limitations of the studies on security assurance.....20
2.10 Comparison of the included studies against the key requirements.....22
3.1 Research questions, research objectives, and the status of each objective.....32
5.1 Mapping between research objectives and MVC components.....46
5.2 Traditional EHR access control compared with the HALAH framework.....46
5.3 Synthea tables loaded by the prototype and the consent module supplied by each.....52
5.4 Validation results of the prototype for consent creation.....55
5.5 Security properties supported by the proposed MVC-based consent architecture.....56
6.1 Validation results of the prototype for identity and authority verification.....69

ABSTRACT

Patient consent is the permission a patient gives for their health data to be used or shared. In most healthcare systems, consent is stored as a record and is checked once, when the permission is first given. After that, access to the data depends on the login of the person asking and on a stored permission in the hospital system. This arrangement does not show whether the person asking is really who they claim to be, whether they have the authority to ask, whether the people who had to agree have all agreed, or whether the consent is still in force at the time of the request.

The problem is harder when the patient cannot decide alone. A child, an elderly patient or a patient without capacity depends on guardians, and in these cases more than one person must agree before the data can be released. Decentralised identifiers (DIDs) and verifiable credentials (VCs) can establish who a participant is and what role they hold, and blockchain can keep a tamper-resistant record of what was agreed. Previous researchers have already proposed each of these technologies for healthcare data sharing. However, through a systematic literature review of 25 primary studies, we have identified that the existing literature treats identity, authority, multi-party approval, purpose, time and the state of the consent as separate conditions. No reviewed study joins them in one decision that is evaluated at every access request, and none proves or tests the decision as a whole.

The primary objective of this study is to propose and develop a trust-oriented authorisation framework termed HALAH, in which patient consent is no longer a stored record but an object that can be evaluated. The consent object carries the identity of the participants, the authority requirements, the guardians named by the patient, the purpose and data scope, the validity period, the lifecycle state and the evidence of every decision. Access is allowed only when the identity check, the approval check, the policy check, the time check and the lifecycle check all pass together, and any failed check gives a refusal that is recorded.

The mechanisms built into HALAH provide the following: (i) a consent model in which consent is represented as an evaluable authorisation object; (ii) verification of the identity and the authority of every participant through DIDs and VCs, so that a valid identity alone does not grant access; (iii) a multi-party authorisation rule in which only verified and distinct approvals from the guardians named by the patient count, and no single party can activate the consent alone; (iv) enforcement of purpose, data scope, validity period and lifecycle state at the time of each request; and (v) an audit ledger that records every decision with the result of each check. Finally, in order to validate the correctness and the security of the proposed framework, software prototyping is chosen as the validation method. The prototype is tested with synthetic patient records, with automated tests, and with attack scenarios in which each check is deliberately bypassed.

CHAPTER 1

INTRODUCTION

1.1 Introduction

Secure and trustworthy data sharing is now needed across organisational boundaries. Modern digital ecosystems involve multiple independent stakeholders, including individuals, healthcare providers, regulatory authorities, researchers, and third-party data processors (Ghafoor et al. 2025; Lomotey, Kumi & Deters 2022; Nguyen et al. 2025). Digital services make collaboration easier, but they also raise a governance question: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain? Healthcare is a clear example of this problem. The increasing digitisation of healthcare information enables patients, healthcare professionals, guardians, researchers, and healthcare organisations to participate in data-sharing processes (Webber et al. 2019; Welzel et al. 2025). At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control.

Traditional access-control architectures are based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms. These approaches can provide effective access control within an organisational boundary, but they become difficult to apply when authorisation decisions involve multiple independent entities. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain. This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, and institutional authorities (Ibrahim et al. 2024; Webber et al. 2019). In these settings, authorisation is a distributed governance problem, not just a check of a user's login and a static permission (Theodorakopoulos, Theodoropoulou & Halkiopoulos 2024).

Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability (Al Mamun, Azam & Gritti 2022; Hellstern et al. 2022; Li, Liu & Shrestha 2026; Nguyen et al. 2025), while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles or authority, and policy-based access-control mechanisms can restrict access to authorised resources. However, an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, or that a subsequent data-access request remains consistent with the conditions originally authorised. Consent must therefore be treated as an active, evaluable part of the authorisation process, not as a static record of permission, extending the dynamic consent perspective (Khalid et al. 2023; Narkhede, Wankhede & Kamble 2025).

1.2 Statement of the Problem

Existing consent-management and decentralised access-control approaches represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created (Jesus & Pandit 2022; Khalid et al. 2023). The relationship between the consent record, the identity of the participants, their authority to act, the applicable policy constraints, and the resulting access decision is frequently treated as separate technical concerns. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information. Even where identity and collective approval have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects identity, authority, multi-party approval, policy, temporal, and lifecycle conditions within a coherent authorisation decision and whose security can be formally and empirically demonstrated. Existing approaches provide important technological components, including decentralised identity and verifiable credentials (Phuyal et al. 2026b; Wu & Zhang 2025), blockchain-based records, multi-party approval mechanisms (Ekholm et al. 2025; Punia et al. 2025; Tan, Chi & Lam 2024), and policy-based access control (Eneh et al. 2026; Khayer et al. 2025; Panagoulias et al. 2026; Román-Martínez et al. 2023), as well as several partial combinations. However, these mechanisms are often investigated independently or integrated primarily at the implementation level. The overarching research question is how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints. The research objectives are operationalised through six corresponding sub-research questions (SRQ1 to SRQ6, referred to as RQ1 to RQ6).

1.3 Research Motivation

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied. Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments (Li et al. 2026b; Ménétrey et al. 2022). Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed. Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems. Future work can therefore investigate how trusted execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.

Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role or permission to participate in a particular decision. Multi-party authorisation concerns whether the required set of independently verified participants has satisfied a defined collective approval condition. Policy compliance concerns whether the requested access is consistent with the

authorised purpose and data scope. Time and lifecycle concern whether the consent is still within its validity window and has not expired or been revoked. Together, these conditions decide whether an authorisation decision has enough basis to be trusted, not only whether access was requested. The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object, C = (I, A, P, T, L, E), that connects the relevant participants, authority requirements, policy constraints, temporal and lifecycle conditions, and evidence associated with an authorisation decision. In C, I is identity and A is authorisation, which holds the guardian set G and the threshold N. P is policy, which covers purpose and data scope. T is time, L is the lifecycle state of the consent, and E is evidence.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient. These four dimensions, RO1 to RO4, collectively define the foundational scope of Multi-Party Patient Consent. RO1 to RO4 are completed with validation and evaluation at the current stage. RO5 adds temporal validity and lifecycle trust, because trust cannot be regarded as permanently established at the moment a consent is created. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state. RO6 concerns formal security assurance and empirical validation. RO5 is in progress, and part of it has already been delivered. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH (History Access Link for Authorised Healthcare) prototype. For RO5, this prototype provides a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation. The remaining formal security assurance and comprehensive empirical evaluation will be conducted in the next stage.

HALAH runs on the Ethereum Sepolia testnet, and the guardian approval rule is currently implemented as N-of-N over the guardian set G. Synthetic healthcare records derived from the Synthea dataset are used to construct representative consent workflows. Security properties are demonstrated through adversarial and negative testing, as well as empirical evaluation using the HALAH prototype and representative healthcare data-sharing scenarios, rather than formal proof. The current stage covers the work delivered so far, while temporal and lifecycle trust, formal security assurance, and comprehensive empirical validation will be developed further in the next stage.

1.4 Decentralised Identity Technology

The framework proposed in this thesis is built on three technologies: decentralised identity, multi-party authorisation and auditable authorisation evidence. This section and the two that follow introduce each of them in turn. Decentralised identity is the first. In a conventional healthcare system, the identity of a doctor, a patient or a guardian is held by one organisation, usually the hospital, and is checked by a login to that organisation. A participant from another organisation cannot be verified without an agreement between the two organisations, and the organisation that holds the account can change or remove it at any time. Decentralised identity moves the identifier and the proof of identity to the participant (Mazzocca et al. 2025; Nassar Kyriakidou,

Papathanasiou & Polyzos 2023). The participant holds an identifier that is not issued by the data holder, and the data holder verifies claims about that participant rather than looking them up in its own directory. In healthcare, this allows a doctor from one hospital, a guardian who is not a patient of any hospital, and a patient to take part in one consent decision without sharing one identity provider (Shanmugham & Senthilkumar 2026; Wu & Zhang 2025).

1.4.1 Decentralised Identifiers (DIDs)

A decentralised identifier (DID) is a string of the form did:method:identifier that names one participant. The method part states how the identifier is resolved and the last part is unique within that method. A DID is controlled by the holder through a cryptographic key, so the holder can prove control of the identifier by signing with that key, and nobody else can speak for it (Mazzocca et al. 2025). A DID on its own says nothing about the role of its holder. It only states that there is one participant and that this participant can sign. In this thesis, every participant has a DID: the patient, each guardian, the doctor and the issuer of credentials. Full resolution of a DID to its public keys, and the proof that a user controls the DID they present, are treated as work for the next stage (Deng et al. 2024; Yin et al. 2025).

1.4.2 Verifiable Credentials (VCs)

A verifiable credential (VC) is a signed statement, issued by one party about another, that can be checked by a third party without going back to the issuer (Flamini et al. 2024; Mazzocca et al. 2025). A credential names the subject by its DID, states one or more claims, such as the role of doctor or guardian and the organisation, carries a validity period, and is signed by the issuer. The credential is what separates identity from authority: the DID shows who the participant is, and the VC shows what the participant may do. This separation is central to the framework, because a valid identity must never be enough on its own to reach patient data.

1.4.3 Trusted Issuers and Credential Verification

A credential is only as good as its issuer. The framework therefore keeps a registry of trusted issuers, such as a health authority, and a credential is accepted only when its signature recovers to the registered key of an issuer in that registry. Four conditions are checked on every credential: the signature is valid, the issuer is trusted, the subject of the credential is the DID that presented it, and the current time lies within the validity period. A credential also has to carry the role that the step requires, so a guardian credential cannot be used to act as a doctor. In the prototype, one demonstration issuer signs all credentials, and the credential check demonstrates the verification rather than the secrecy of the issuer key.

1.5 Multi-Party Authorisation

Multi-party authorisation is a rule under which a decision needs the agreement of more than one party before it takes effect. In healthcare consent, the parties are the people who must agree before a patient's data can be released: the patient, and for a minor or an incapacitated patient, the guardians (Hagström et al. 2024; Webber et al. 2019). The reviewed literature contains several forms of multi-party approval. Madine et al. (2020) require a regulator and a guardian threshold when the patient is incapacitated, Wu et al. (2022) use a threshold of investigators to admit and revoke records, Zhao and Su (2024) delegate authority through a threshold, Tan, Chi and Lam (2024) let the patient appoint verifiers, and Maruthi and Singh (2025) treat the guardians of an unconscious patient as the approving parties.

In this thesis, multi-party authorisation is defined by two elements that the patient sets when the consent is created: the guardian set G, which lists the participants whose approval is required, and the threshold N, which is the number of valid approvals needed. An approval counts only when it comes from a member of G, when it is signed by that member, and when that member has not already approved the same consent. An approval from a signer outside G, or a second approval from the same guardian, does not advance the count. In the current prototype, every listed guardian must approve, so N equals the size of G, and the rule has been demonstrated with two guardians.

1.6 The Relationship between Multi-Party Authorisation and Patient Consent

Patient consent and multi-party authorisation are often handled by different parts of a system. The consent is a record of what the patient allowed, and the approval of the guardians is a separate step that happens once, for example at registration (Ekholm et al. 2025) or when a patient is admitted (Wu et al. 2022). Once that step has passed, later requests for data do not look at it again. In this thesis, the two are joined. The guardian set and the threshold are part of the consent object itself, and the approvals that the guardians give are stored with the consent as evidence. A consent with fewer approvals than its threshold stays pending and cannot release any data. A consent that reached its threshold becomes active, and the approvals are checked again whenever a doctor asks for data, together with the identity, policy, time and lifecycle conditions. Multi-party authorisation is therefore not a gate that the consent passes once, but a standing condition that the consent must keep satisfying for as long as it is used.

1.7 Purpose of Using Multi-Party Authorisation in Consent Management

There are three reasons for placing multi-party authorisation inside consent management rather than beside it. The first is that it removes the single point of decision. Where a patient cannot decide alone, no one guardian, and no hospital account, should be able to release the data on their own. The second is that it keeps the approving set under the control of the patient. In the reviewed studies, the parties who must approve are usually chosen by the institution or by a delegate (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024). In the proposed framework, the patient names them when the consent is created, and the system enforces that list. The third is that it makes the approval verifiable after the event. Each approval is a signature over the consent identifier and the guardian identifier, so an auditor can later confirm who approved which consent, and a signature cannot be moved from one consent to another.

1.8 Authorisation Evidence and Auditability

A decision to release patient data must be explainable afterwards. It is not enough to record that access happened; the record must show why it was allowed or refused. The framework treats this as the evidence component E of the consent object. For every request, the result of each check is written down together with the decision, so that a later reader can see whether the requester was verified, whether the approvals were sufficient, whether the purpose and scope were within the consent, whether the consent was in its validity period, and whether its lifecycle state allowed access. Blockchain or other tamper-resistant storage can be used to preserve selected evidence (Andrew et al. 2023; Li, Liu & Shrestha 2026), but in this thesis the blockchain is not the source of trust. Trust comes from the checks themselves; the storage only makes their record harder to alter.

1.8.1 The Audit Ledger

In the prototype, the evidence is kept in an audit ledger. The ledger is an append-only list of events. Each event records the actor, the action, the consent identifier, the time, the result and, for an access decision, the outcome of the five checks. A digest of the key fields of each event is computed and stored with it, so that any later change to a stored event can be detected. The ledger records the creation of a consent, each guardian approval, each state check, each data access and each revocation. Refusals are recorded as well as grants. The auditor interface reads this ledger and presents the decisions in the order in which they were made.

1.9 Consent Management Systems

A consent management system records what a patient has allowed and makes that record available to the systems that hold the data. The simplest systems store a signed form. Dynamic consent systems let the patient change the permission over time and notify the parties affected (Albalwy, Brass & Davies 2021; Khalid et al. 2023). Purpose-based systems tie the permission to a stated purpose, such as treatment or research (Tith et al. 2020), and consent receipts give the patient a readable record of each permission (Jesus & Pandit 2022). More recent systems place the consent on a blockchain so that it cannot be altered quietly, and some of them connect it to an access-control layer (Jaiman & Urovi 2020; Phuyal et al. 2026a; Zhang, Kan & Huang 2022). All of these systems have one thing in common: the consent is treated as a record of a permission. The access decision that follows is made by another component, usually an access-control list or a role check, and that component looks at the consent record only to confirm that it exists.

1.10 Challenges Faced by Current Consent Management Systems

The systematic literature review in Chapter 2 identifies six challenges in the current generation of consent management systems. They are summarised here and stated in full in Chapter 3.

First, consent is represented as a record of permission rather than as an object that can be evaluated, and the few evaluable consent objects carry only some of the conditions that an access decision needs. Second, a valid decentralised identity establishes who a participant is but not what the participant is authorised to do, and authority is checked separately from authentication in only a minority of the reviewed studies. Third, multi-party approval appears as a contingency path, an admission gate or a registration-time co-consent, but not as a standing condition of every access decision with an approving set defined by the patient. Fourth, purpose and data-scope constraints are rarely bound to the same decision as identity, authority and multi-party approval. Fifth, validity periods, lifecycle state and revocation are often enforced on a credential or at registration rather than at the time of each request. Sixth, the authorisation decision as a whole is neither formally proved nor systematically tested.

The first five challenges together mean that the conditions for a trustworthy decision exist but are never joined. The sixth means that, even where they are joined, nobody has shown that the joined decision behaves as intended. This thesis addresses both.

1.11 Research Contribution

1.11.1 Scientific Contribution

The scientific contributions of this research are threefold. First, this research proposes a trust-centric consent model that integrates identity, authority, multi-party approval, and policy constraints into a unified healthcare authorisation framework. Second, this

research proposes a multi-party authorisation mechanism that requires approval from multiple verified participants before granting healthcare data access, where collective consent is required. Third, this research proposes a trust-aware authorisation approach that evaluates identity, authority, collective approval, and policy compliance when determining healthcare data-access permissions.

1.11.2 Social Contribution

The social contributions of this research are also threefold. First, this research aims to help patients and their guardians manage consent for sharing sensitive healthcare information, supporting greater control over healthcare data access. Second, this research aims to support patient privacy by restricting healthcare data access according to authorised purposes and data scopes. Third, this research aims to support transparency and accountability in healthcare data sharing by providing verifiable records of consent activities and access decisions.

1.12 Thesis Plan

This thesis is organised into eleven chapters.

Chapter 1 introduces the research. It states the problem, gives the motivation, introduces the three technologies on which the framework is built, summarises the challenges in current consent management systems, and lists the contributions of the thesis.

Chapter 2 presents the systematic literature review. It defines the six key requirements for trustworthy multi-party consent authorisation, describes the process used to search, select and assess the literature, reviews the 25 primary studies in six streams, compares them against the requirements, and identifies the research gap.

Chapter 3 states the research gap, the main research question, the six sub-research questions and the six research objectives, and shows how they form one integrated problem.

Chapter 4 presents the research methodology, which is design science research, and gives an overview of the proposed solution for each research question.

Chapter 5 presents the research architecture, based on the model-view-controller pattern, and the trust-centric consent model of Research Objective 1, in which consent is represented as the evaluable object $C = (I, A, P, T, L, E)$.

Chapter 6 presents the decentralised identity and authority verification mechanism of Research Objective 2.

Chapter 7 presents the multi-party authorisation mechanism of Research Objective 3.

Chapter 8 presents the policy- and context-aware access control mechanism of Research Objective 4.

Chapter 9 presents the temporal validity and consent lifecycle controls of Research Objective 5.

Chapter 10 presents the formal security assurance and the empirical validation of Research Objective 6, together with the working of the HALAH prototype, the dataset used, the live scenarios, the measured results and the attack scenarios.

Chapter 11 concludes the thesis and sets out the directions for future work.

1.13 Conclusion

This chapter introduced the research. It described the setting in which patient data are shared across organisations, stated the problem that current consent and access-control

systems treat consent as a stored record rather than as a condition that is evaluated at each request, and gave the motivation for a trust-oriented approach in which trust is the outcome of several independently verified conditions. It introduced decentralised identity, multi-party authorisation and auditable authorisation evidence as the three technologies on which the proposed framework is built, summarised the six challenges found in current consent management systems, and listed the scientific and social contributions of the thesis. The next chapter reviews the literature systematically and establishes the gap that this thesis addresses.

CHAPTER 2

A SYSTEMATIC LITERATURE REVIEW

2.1 Introduction

The review does not only list technologies that can be applied to healthcare data sharing. It examines how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing (Kaplow et al. 2024; Kharlamov, Hohmann & Parry 2023; McClelland & Harper 2023; Narkhede, Wankhede & Kamble 2025; Webber et al. 2019). Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management (Andrew et al. 2023; Arbabi et al. 2023; Ghosh et al. 2023; Nguyen et al. 2025; Turan, Hashimzai & Qiam 2025). Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication (Deng et al. 2024; Flamini et al. 2024; Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023; Parameswarath, Gope & Sikdar 2022; Yin et al. 2025). Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information (Jiang et al. 2023; Nazir et al. 2026; Tawfik et al. 2025; Yin et al. 2024). However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. Having the security mechanisms is one thing. Combining them into one trustworthy authorisation decision is another.

The structure of this chapter is as follows. Section 2.2 presents the six key requirements that a trustworthy multi-party consent authorisation should satisfy and that serve as the basis of the comparison. In Section 2.3, the process adopted for shortlisting the papers chosen for this SLR is discussed, including the criteria for searching the literature, the inclusion and exclusion criteria and the quality evaluation. Section 2.4 presents a summary of all the papers that were shortlisted, 25 in all, in six streams, and states the research gaps from the requirement perspective. In Section 2.5, the trust-oriented multi-party consent authorisation framework proposed in this thesis is positioned against the requirements. Finally, Section 2.6 concludes the SLR.

2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation

Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The six requirements below collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation. Each matches one sub-research question (Chapter 3), and each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework.

2.2.1 Req 1: Representation of consent as an evaluable authorisation object

- Rather than representing consent as a simple association between a patient, a requester, and a permission, consent should be represented as a structured and evaluable authorisation object. The object should incorporate identity information, authority requirements, policy constraints on purpose and data scope, temporal validity, lifecycle state, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

2.2.2 Req 2: Decentralised verification of identity and authority

- Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. Participants should establish persistent and cryptographically verifiable identifiers without dependence on a single identity provider. Identity verification establishes who is participating, while authority verification determines whether that entity satisfies the requirements associated with a particular consent. This separation prevents successful authentication from being interpreted as automatic authorisation.

2.2.3 Req 3: Multi-party authorisation through a verifiable threshold

- Multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access. A predefined threshold of independent approvals from designated parties should be modelled as an explicit and independently verifiable security condition within the consent object.

2.2.4 Req 4: Policy- and context-aware enforcement at the time of access

- A requester may possess a valid identity, valid credentials, and even the required multi-party approval while still requesting information outside the scope authorised by the patient. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent. This applies to every request, because many unauthorised disclosures are caused by legitimate requesters who exceed their scope (Jiang et al. 2023).

2.2.5 Req 5: Temporal validity and lifecycle control of consent

- A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. The requirement is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, immediate and verifiable revocation, and unauthorised state transitions are correctly enforced at every request.

2.2.6 Req 6: Verifiable auditability and security assurance

- A system may execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision. Every decision should preserve verifiable evidence to explain the reason for that decision. Formal analysis or systematic adversarial testing should provide a complementary layer through which the expected security properties of the authorisation model can be explicitly defined and examined.

2.3 Process Adopted for Shortlisting the Papers for SLR

This section details the process adopted to identify the relevant papers to be reviewed in the SLR. A four-step process was adopted:

Step 1: Searching the literature. This step involves defining the search terms, identifying the data sources and the process of data collection.

Step 2: Inclusion and exclusion criteria. Criteria are defined to guide the selection of the most relevant studies.

Step 3: Quality evaluation. Each of the full-text studies is reviewed against six quality evaluation questions, one for each key requirement.

Step 4: Data analysis. After reviewing the selected studies, data are extracted, recorded and categorised into streams.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 statement (Page et al. 2021). PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. A written protocol (Protocol v1.1) fixed the review questions, databases, master query, eligibility criteria, codebook, and quality items before screening. All screening, coding, and quality assessment were carried out by the author. The review is guided by the six key requirements of Section 2.2, and the six quality evaluation questions of Step 3 are derived from them, one for each requirement.

2.3.1 Step 1: Criteria for Searching the Literature

This step involved deciding the databases to search, the search string, the information required from each record and the publication period of the records.

The literature search was conducted using the following academic databases including 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) ProQuest Science and Technology, 6) Scopus, and 7) Web of Science. These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies. One master query of three concept blocks joined by AND covered healthcare data, consent and authorisation, and trust and multi-party concepts. The search string was ("Healthcare" OR "Health Data" OR "Medical Records") AND ("Consent" OR "Authorisation" OR "Authorization") AND ("Trust" OR "Multi-party" OR "Multi-party Approval"). The search strings were constructed using Boolean operators and were adapted only to the syntax requirements of each database.

Table 2.1 shows the seven databases and the number of records retrieved from each.

Table 2.1: Databases searched and records retrieved

S/N	Database	Records
1	SpringerLink	46
2	Scopus	38
3	IEEE Xplore	27
4	ProQuest Science and Technology	24
5	Web of Science	19
6	ScienceDirect	14
7	ACM Digital Library	11
	Total	179

2.3.2 Step 2: Inclusion and Exclusion Criteria

Not all the records identified in the previous step are considered in the SLR. They were further shortlisted according to the following inclusion and exclusion criteria.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening. Each study is cited by the year of the journal issue or proceedings volume in which it appeared, not the year it was first published online.

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. Inclusion required healthcare data (IC1), consent, authorisation, access control, trust, or governance relevant to data access (IC2), and a mechanism, model, system, or evaluation relevant to a review question (IC3). Studies also had to be peer-reviewed English papers with full text (IC4 to IC7). The search was restricted to studies published between 2020 and 2026. The exclusion criteria removed, among others, studies outside healthcare or the authorisation scope, studies of authentication alone or with only a superficial mention of consent, non-peer-reviewed work, duplicate publications, and secondary reviews, although no study was excluded for failing to support the proposed research gap. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the review questions rather than by the presence of a single keyword.

Inclusion criteria:

1. Healthcare data sharing (IC1).

2. Consent or authorisation relevant to data access (IC2).

3. A model, mechanism, system or evaluation that addresses a review question (IC3).

4. Peer-reviewed English paper with full text (IC4 to IC7).

5. Publication between 2020 and 2026.

Exclusion criteria:

1. Outside healthcare or the authorisation scope.

2. Authentication alone or a superficial mention of consent.

3. Non-peer-reviewed work and duplicate publications.

The stages of evaluating and selecting the relevant papers for the SLR are summarised in Table 2.2.

Table 2.2: Summary of the stages of evaluating and selecting the relevant papers for the SLR

Evaluation stage	Method	Assessment criteria	Records
1st	Identify the related studies from the seven databases	Match the search string	179 identified
2nd	Remove duplicate records	Same title, author, DOI and publication year	21 removed, 158 remain
3rd	Screen the titles	Within healthcare consent or authorisation; otherwise exclude	76 excluded, 82 remain
4th	Screen the abstracts	Relevant to a review question; otherwise exclude	43 excluded, 39 remain
5th	Assess the full texts	Eligibility criteria and the quality evaluation of Step 3	14 excluded, 25 included

Figure 2.1 presents the PRISMA flow diagram for this review, which summarises the identification, screening, eligibility, and inclusion stages of the SLR. The seven database

searches returned 179 records: 46 from SpringerLink, 38 from Scopus, 27 from IEEE Xplore, 24 from ProQuest, 19 from Web of Science, 14 from ScienceDirect, and 11 from the ACM Digital Library. After 21 duplicates were removed, 158 records were screened by title, and 76 were excluded. The abstracts of the remaining 82 records were screened, and 43 were excluded. The full texts of 39 studies were then assessed for eligibility, 14 were excluded, and 25 studies were included in the analysis.

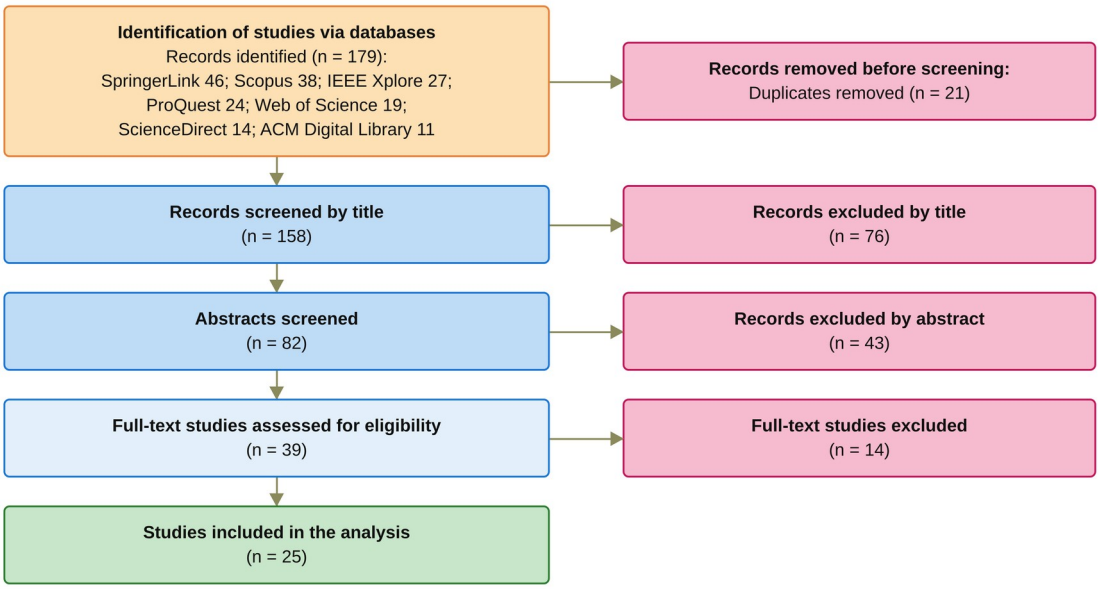


Figure 2.1: PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages.

2.3.3 Step 3: Quality Evaluation

The 39 full-text studies were retrieved and critically evaluated based on the six quality evaluation questions, one for each key requirement of Section 2.2, as follows:

QA1: Does the study define a consent model covering identity, authority, policy, and evidence?

QA2: Does the study verify participant identities and their authorisation authority?

QA3: Does the study support consent decisions requiring approval from multiple authorised participants?

QA4: Does the study enforce purpose, data scope, and approval rules before allowing access?

QA5: Does the study manage consent validity, expiry, and revocation?

QA6: Does the study validate security and access decisions through formal analysis or implementation testing?

Each question was answered Yes or No, and any study which has at least three Yes answers to the six questions, and meets the eligibility criteria of Step 2, is included in this SLR. Of the 39 full-text studies, 25 satisfied the criteria, as shown in Table 2.3. Each included study was then coded Yes or No against each of the six requirements, Req 1 to Req 6, with a page reference for every Yes. A study is core if its gap-impact verdict is contradicts, weakens or narrows, or if it provides a multi-party approval mechanism. Of the 25 included studies, S1 to S25, 23 are core studies and 2 are supporting studies (Albalwy, Brass & Davies 2021; Li et al. 2026a).

2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas

Each of the shortlisted papers was analysed according to its scope, topic and contribution to the review questions. Based on the analysis, each study was placed in one of six streams, one per requirement: consent representation (Req 1), identity and authority (Req 2), multi-party authorisation (Req 3), policy and context (Req 4), temporal and lifecycle (Req 5) and security assurance (Req 6). Table 2.3 lists the 25 primary studies with their authors, year and title. The papers in each stream are summarised in the next section, and their issues and limitations with respect to the key requirements defined in Section 2.2 are discussed.

Table 2.3: Listing of the 25 primary studies identified after the selection process

Study	Authors and year	Article title
S1	Abbasi et al. (2026)	Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains
S2	Albalwy et al. (2021)	A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study
S3	Al Amin et al. (2023)	Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach
S4	Ekholm et al. (2025)	Implementing electronic informed consent in rare disease genomics
S5	Eneh et al. (2026)	Demo: EdgeConsent: On-Chain Attribute-Based Access Control for Data Consent Management
S6	Hagström et al. (2024)	Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland
S7	Jaiman and Urovi (2020)	A Consent Model for Blockchain-Based Health Data Sharing Platforms
S8	Zhao and Su (2024)	A threshold traceable delegation authorization scheme for data sharing in healthcare
S9	Li et al. (2026a)	Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization
S10	Madine et al. (2020)	Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records
S11	Maruthi and Singh (2025)	Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain
S12	Mei et al. (2026)	Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT
S13	Panagoulias et al. (2026)	Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage
S14	Phuyal et al. (2026b)	Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR↔FHIR Translation
S15	Phuyal et al. (2026a)	A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data
S16	Punia et al. (2025)	An access control system for cloud-based healthcare systems driven by blockchain
S17	Román-Martínez et al. (2023)	Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing
S18	Hema et al. (2026)	Patient Centric Cryptographic Protection of Cloud Electronic Health Records
S19	SooHoo et al. (2026)	Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems

Study	Authors and year	Article title
S20	Tan et al. (2024)	Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification
S21	Tith et al. (2020)	Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology
S22	Tremper et al. (2026)	Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management
S23	Tseng et al. (2025)	EMR-Chain: Decentralized Electronic Medical Record Exchange System
S24	Wu et al. (2022)	Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data
S25	Wu and Zhang (2025)	HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID

2.4 Summary of Papers Shortlisted in the SLR

The extracted data were organised into thematic categories corresponding to the research questions. Each included study was assigned to one stream, normally the one on which it is coded most strongly. S6 (Hagström et al. 2024) is placed in the multi-party stream for its guardian access gate, although it is not graded Yes on Req 3.

2.4.1 Consent representation and blockchain-based consent governance (Req 1)

Two of the three studies of this stream are deployed platforms that do not fully satisfy Req 1. SooHoo et al. (2026) describe the iAgree portal across three United States health systems with a permissioned Ethereum audit contract, but consent enforcement is outside its scope. Tremper et al. (2026) report ten years of the Mainzelliste service with FHIR consent directives, but specify no check semantics and no demonstrated enforcement of withdrawal. The two platforms are single-party systems. Al Amin et al. (2023) model informed consent as a patient-driven policy object with hash integrity, but specify no purpose condition and report no measured results. The supporting references represent consent as a permission indicating whether a particular party is allowed to perform a specified operation (Akter & Sanam 2025; Prashanth et al. 2024), as conditions fixed at encryption time (Zhang, Kan & Huang 2022), or as a key issued by the patient for each request (Teeda & Subba Rao 2026). The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. Table 2.4 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.4: Descriptions, issues and limitations of the studies on consent representation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S3 Al Amin et al. (2023)	Informed consent is modelled as a patient-driven policy object with hash integrity, which an authorisation module conjoins with other policies inside a smart contract.	Purpose is not a condition, the time and expiry conditions are specified but not enforced, the only multi-party element is a 2-of-2 co-signature at registration, and the Goerli evaluation reports no measured results.	Yes	No	No	No	No	No
S19 SooHoo et al. (2026)	The authentication and authorisation processes of the iAgree portal across three United States health systems, using OAuth2, SMART on FHIR, and one-time passwords, with a permissioned Ethereum audit contract.	Consent enforcement is outside its scope, a single patient decides, identity and authority are not separated, revocation is claimed but not tested, and there are no formal methods.	No	No	No	No	No	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S22 Tremper et al. (2026)	Ten years of the Mainzelliste production service for pseudonymisation, record linkage, and informed consent management, with purpose-scoped FHIR consent directives and automated consent checks.	The consent checks have no specified semantics and no demonstrated enforcement of withdrawal, its multi-party computation parties are linkage units rather than authorisers, and no consent decision is verified.	No	No	No	No	No	No

2.4.2 Decentralised identity and authority trust (Req 2)

Req 2, which needs both identity and authority, is graded Yes in only 7 of the 25 studies in Table 2.10. Phuyal et al. (2026b) present the most integrated system, with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs. Its licensing-body credential asserts role and scope of practice separately from authentication, which is among the strongest Req 2 evidence in the corpus. However, a single patient grants consent, the stored expiry is not checked, there is no threat model, and the companion architecture (Phuyal et al. 2026a) is design-only. Tseng et al. (2025) verify authority-issued roles separately from X.509 identities, although without W3C identifiers and with purpose logged but never evaluated. Neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient's information.

Table 2.5 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.5: Descriptions, issues and limitations of the studies on identity and authority

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S14 Phuyal et al. (2026b)	Cross-institution health data sharing with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs, where a licensing-body credential asserts role separately from authentication.	A single patient grants consent, the stored expiry is not checked, purpose is handled only at the interface, and there is no threat model.	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	A design-science architecture for dynamic and auditable patient consent in secondary use, using FHIR Consent with purpose, scope, actors, and validity period, anchored on chain, with conceptual VC validation at a gateway.	The architecture is design-only and is neither implemented nor evaluated, and delegation through VCs is not joint multi-party approval.	No	No	No	No	No	No
S23 Tseng et al. (2025)	EMR-Chain, a decentralised electronic medical record exchange that verifies authority-issued roles separately from X.509 identities and enforces token expiry at the validator.	It has no W3C identifiers, purpose is logged but never evaluated, scope is hospital-level only, the patient and requester signatures authenticate the request rather than add an independent authoriser, and revocation does not invalidate issued tokens.	No	Yes	No	No	No	No

2.4.3 Multi-party authorisation and collaborative consent (Req 3)

Req 3 is graded Yes in 6 of the 25 studies and No in 19, across six mechanism classes. Madine et al. (2020) require a regulator and a guardian threshold on the incapacitated

path, but a single patient key suffices on the normal path. Wu et al. (2022) apply a (t, n) investigator threshold to record admission and revocation, and Abbasi et al. (2026) use a Shamir (5, 3) threshold for key custody. Punia et al. (2025) conjoin an M-of-N multi-signature with an attribute and role policy, but a single emergency officer can bypass the threshold. Tan et al. (2024) use patient-appointed verifiers as a contingency, (Ekholm et al. 2025) reports guardian co-consent at registration time, and (Hagström et al. 2024) gates guardian access by the minor's consent and a clinician's capacity assessment. No reviewed study evaluates a threshold predicate over a patient-designated guardian set on every request, and none does so together with the policy, temporal, and lifecycle conditions. Multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access.

Table 2.6 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.6: Descriptions, issues and limitations of the studies on multi-party authorisation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	Decentralised EHR management in which a Shamir (5, 3) threshold reconstructs a symmetric key, and automated oracles release their shares according to the requester's on-chain role.	The threshold is over key custodians rather than authorisers, the patient share is not required, purpose is not evaluated, and no authorisation decision is verified despite extensive performance measurement.	No	No	No	No	No	No
S4 Ekholm et al. (2025)	A deployed electronic informed consent platform for rare disease genomics, in which a minor's consent is valid only when all legal guardians sign, and guardianship is verified against the Swedish Population Register.	The guardian co-consent applies at registration rather than at each access request, the platform is centralised and described with little technical detail, and there is no temporal, purpose, or formal assurance condition.	No	Yes	Yes	No	No	No
S6 Hagström et al. (2024)	A comparative case study of national patient portals, in which a clinician's capacity assessment and the minor's consent jointly gate guardian access, with register-verified guardianship and enforced age windows.	The mechanism is centralised and applied at documentation time, and the guardian is the party whose proxy access is gated rather than a co-authoriser of the patient's access decision.	No	Yes	No	No	Yes	Yes
S10 Madine et al. (2020)	Fully decentralised multi-party consent management in which, on the incapacitated path, approvals from a regulator and a guardian threshold are required on one access request, and stale attestations stop counting.	On the normal path a single patient key authorises, so multi-party approval is a contingency. Purpose and data-category policy are absent, revocation after delivery is not possible, and there is no formal assurance.	Yes	Yes	Yes	No	Yes	No
S16 Punia et al. (2025)	MedXBlock, a blockchain-driven access control system for cloud healthcare that combines an institutional M-of-N multi-signature with a conjunctive role and attribute policy evaluated with deny-by-default.	The signers are doctors and administrators rather than patient-side parties, the threshold sits outside the decision predicate and a single emergency officer can bypass it, there is no purpose term, and no authorisation decision is verified.	No	No	Yes	Yes	Yes	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S20 Tan et al. (2024)	Sharing of personal health records with multi-party pre-authorisation verification, in which a (t, n) threshold of patient-appointed verifiers each validate the grant, its expiry, and the revocation list before releasing a key share.	The joint approval is a pre-delegated contingency for an unconscious patient rather than a standing condition, purpose and data scope are not evaluated, and the gate is not evaluated empirically as an authorisation decision.	Yes	Yes	Yes	No	No	No
S24 Wu et al. (2022)	Trust computing and privacy-preserving smart contracts for multi-site clinical trial data, in which a (t, n) investigator threshold signature governs trial admission to the ledger and consent revocation.	The consent grant is unilateral, the voters are institution-side investigators, the vote reduces to a hash-integrity check, there is no policy engine, and there is no formal assurance.	No	No	No	No	No	No

2.4.4 Policy- and context-aware access control (Req 4)

Tith et al. (2020) match a purpose tree in chaincode, and Jaiman and Urovi (2020) match ontology terms against the patient's consent. Albalwy et al. (2021) evaluate a hashed policy tree of data type, role, and purpose, and Román-Martínez et al. (2023) evaluate the FHIR purpose-of-use through XACML. Req 4 is graded Yes in 10 studies and No in 15 in Table 2.10. However, purpose-of-use enters the decision in only six studies (Eneh et al. 2026; Panagoulias et al. 2026), and every one is graded No on Req 3. Consequently, purpose and data-scope constraints are not carried by the consent object C and evaluated together with the identity, authority, and multi-party conditions.

Table 2.7 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.7: Descriptions, issues and limitations of the studies on policy and context

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S2 Albalwy et al. (2021)	A blockchain-based dynamic consent proof of concept for clinical genomic data, in which a hashed policy tree of data type, role, and purpose is evaluated by the smart contract.	A single patient sets and cancels consent, the requester's role and credentials are not verified, time is applied only at the delivery layer, and there is no formal assurance.	Yes	No	No	Yes	No	Yes
S7 Jaiman and Urovi (2020)	A consent model in which ontology terms requested by a data requester are matched against the patient's consent inside the smart contract, with denial tested across requester profiles.	Security assurance is explicitly outside its scope, and there is no multi-party approval.	Yes	No	No	Yes	No	Yes
S17 Román-Martínez et al. (2023)	A blockchain-based service-oriented architecture on Hyperledger Fabric for consent management, access control, and auditing, in which FHIR purpose-of-use limits are evaluated per resource through XACML.	There is no withdrawal or expiry path, and the experiments validate only the blockchain component.	Yes	No	No	Yes	No	No
S21 Tith et al. (2020)	A purpose-based consent model on Hyperledger Fabric, in which a consent tuple of role, doctor identifiers, action, and intended purpose is matched against a purpose tree in chaincode at request time.	Consent is given by a single patient, the tuple has no temporal element, the effect of withdrawal is not tested, identity uses Fabric certificates without DID or VC, and there is no formal verification.	Yes	No	No	Yes	No	No

2.4.5 Temporal validity and consent lifecycle (Req 5)

A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Eneh et al. (2026) present EdgeConsent, which enforces temporal validity inside the decision predicate, although its lifecycle is only an active flag. Temporal validity must also be evaluated together with the lifecycle state of the consent. Hema et al. (2026) bind the expiry into key derivation, and Panagoulias et al. (2026) enforce revocation at decision time across 43,500 simulated attempts in a single-node ledger. Req 5 is graded Yes in 8 studies, a post-revocation denial is demonstrated only by Phuyal et al. (2026b), which enforces revocation but not expiry, so it does not fully satisfy Req 5, and the four stream-5 systems that enforce time inside the decision are all single-party, with Li et al. (2026a) doing so through the credential rather than the consent.

Table 2.8 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.8: Descriptions, issues and limitations of the studies on temporal validity and lifecycle

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S5 Eneh et al. (2026)	EdgeConsent, a demonstration of on-chain attribute-based access control in which consent rules with purpose, data category, and notBefore and notAfter bounds are evaluated at decision time.	A two-page demonstration with weak identity and authority trust and no DID or VC, no multi-party approval, a lifecycle that is only an active flag, and preliminary local evaluation without formal assurance.	Yes	No	No	Yes	Yes	No
S9 Li et al. (2026a)	A hybrid RBAC and smart contract scheme with attribute-based authentication for fine-grained EMR access in IoMT, which enforces credential expiry at every sharing interaction.	Time is enforced in the decision through the credential rather than the consent, which is why Req 5 is graded Yes, but the consent itself carries no enforced validity window, and there is no multi-party approval.	No	No	No	Yes	Yes	No
S13 Panagoulias et al. (2026)	Blockchain-enabled trust and compliance for clinical AI, in which an Allow predicate over time, revocation, role, and purpose is evaluated before execution and denials are recorded, verified across simulated attempts with zero consent drift.	A simulated single-node prototype with set-membership policy and aggregate deny attribution, without multi-party approval or identity depth, and the authors declare no formal assurance.	Yes	No	No	Yes	Yes	Yes
S18 Hema et al. (2026)	Patient-centric cryptographic protection of cloud EHRs, in which a signed consent token, role, and expiry are inputs to key derivation, so that access becomes a cryptographic precondition and role-scoped keys separate authority from identity.	Consent is issued from a single patient key, identity relies on a cloud authentication service without DID or VC, and assurance is limited to an adversary model.	Yes	No	No	Yes	Yes	No

2.4.6 Formal security assurance and empirical validation (Req 6)

Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable. Wu and Zhang (2025) present HealthDID, with three game-based definitions and three theorems proved by reduction, although the proofs cover only the identity and authority fragment. Zhao and Su (2024) and Maruthi and Singh (2025) prove threshold gates in isolation, and Mei et al. (2026) prove a static encryption predicate. Req 6 is graded Yes in 9 of the 25 studies: formal assurance is provided by only 4 of them, and the other 5 rest on empirical validation. An inverse

relation between predicate breadth and assurance strength was observed. Few studies execute adversarial scenarios that examine whether security controls can resist deliberate attempts to circumvent the authorisation process.

Table 2.9 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.9: Descriptions, issues and limitations of the studies on security assurance

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S8 Zhao and Su (2024)	A threshold traceable delegation scheme in which the patient delegates a threshold of l already-authorised users, who must jointly authorise an out-of-policy requester, with unforgeability argued under DBDH.	The authorisers are consumer-side delegates rather than patient-side stakeholders, the patient's own decision is unilateral, a trusted authority escrows keys, and there is no temporal, lifecycle, or purpose condition.	No	No	Yes	No	No	Yes
S11 Maruthi and Singh (2025)	Protection of IoMT data for unconscious patients, in which t-of-n patient-designated relatives release access through threshold proxy re-encryption, and the hospital and relatives are authenticated on chain.	Policy and temporal conditions are not evaluated, and the proofs cover the threshold gate in isolation rather than the complete decision.	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	An efficient dual-revocation CP-ABE scheme for IoMT that terminates access immediately through ciphertext update, motivated by consent withdrawal, with a security reduction under q-BDHE.	The proof covers a static encryption predicate, revocation operates at scheme level rather than on a consent object, and there is no multi-party approval.	No	No	No	Yes	Yes	Yes
S25 Wu and Zhang (2025)	HealthDID, a DID-based privacy-preserving EMR sharing system with three game-based definitions and three theorems proved by reduction, in which a zero-knowledge proof binds the authorisation to a specific requester.	The proofs cover only the identity and authority fragment, multi-party refers to the privacy requirements of several stakeholders rather than joint approval, and there are no policy, temporal, or lifecycle conditions.	Yes	Yes	No	No	No	Yes

2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily

establish that the requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient, or that the consent is still valid in time and lifecycle state at the moment of the request.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent, and the temporal validity and lifecycle state of the consent at the time of the request. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated Trust Computing framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent, and ensuring that the authorisation remains valid only within the time interval and lifecycle state of the consent. The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

Existing approaches solve single dimensions of trustworthy data sharing, each at a different layer of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. The systems that enforce purpose and time are authored by a single patient and lack a formal argument. The multi-party systems carry no purpose condition, whereas the proved schemes either omit policy, temporal validity, and lifecycle or, as in (Mei et al. 2026), prove only a static encryption predicate. Table 2.10 summarises the 25 studies against the six requirements, where Yes denotes that the requirement is fully satisfied and No that it is not fully

satisfied. In the Req 6 column each study takes the higher of its formal assurance grade and its empirical validation grade.

Table 2.10: Comparison of the included studies against the key requirements

Study	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	No	No	No	No	No	No
S2 Albalwy et al. (2021)	Yes	No	No	Yes	No	Yes
S3 Al Amin et al. (2023)	Yes	No	No	No	No	No
S4 Ekholm et al. (2025)	No	Yes	Yes	No	No	No
S5 Eneh et al. (2026)	Yes	No	No	Yes	Yes	No
S6 Hagström et al. (2024)	No	Yes	No	No	Yes	Yes
S7 Jaiman and Urovi (2020)	Yes	No	No	Yes	No	Yes
S8 Zhao and Su (2024)	No	No	Yes	No	No	Yes
S9 Li et al. (2026a)	No	No	No	Yes	Yes	No
S10 Madine et al. (2020)	Yes	Yes	Yes	No	Yes	No
S11 Maruthi and Singh (2025)	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	No	No	No	Yes	Yes	Yes
S13 Panagoulias et al. (2026)	Yes	No	No	Yes	Yes	Yes
S14 Phuyal et al. (2026b)	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	No	No	No	No	No	No
S16 Punia et al. (2025)	No	No	Yes	Yes	Yes	No
S17 Román-Martínez et al. (2023)	Yes	No	No	Yes	No	No
S18 Hema et al. (2026)	Yes	No	No	Yes	Yes	No
S19 SooHoo et al. (2026)	No	No	No	No	No	No
S20 Tan et al. (2024)	Yes	Yes	Yes	No	No	No
S21 Tith et al. (2020)	Yes	No	No	Yes	No	No
S22 Tremper et al. (2026)	No	No	No	No	No	No
S23 Tseng et al. (2025)	No	Yes	No	No	No	No
S24 Wu et al. (2022)	No	No	No	No	No	No
S25 Wu and Zhang (2025)	Yes	Yes	No	No	No	Yes

The matrix supports four observations. First, counting only full satisfaction, Req 1 is met by 12 of the 25 studies, Req 2 by 7, Req 3 by 6, Req 4 by 10, Req 5 by 8, and Req 6 by 9. Second, no study satisfies all six, the maximum of four is reached by (Madine et al. 2020) and (Panagoulias et al. 2026), and five studies fully satisfy none. Third, Req 1 with Req 4 is the most frequent pair, in seven studies, whereas Req 2 and Req 4 never co-occur in full. Req 3 co-occurs with Req 4 only in (Punia et al. 2025), whose threshold lies outside the policy predicate and whose policy carries no purpose term. Similarly, Req 3 co-occurs with Req 6 only in (Maruthi & Singh 2025; Zhao & Su 2024). Fourth, the two quadruples are complementary, since Madine et al. (2020) lack full policy and assurance, whereas Panagoulias et al. (2026) lack multi-party approval and full identity depth.

The comparison shows that the contribution of this research is the explicit relationship it establishes among existing technologies, not their replacement. The consent object C carries the identity, authority, threshold, policy, temporal, and lifecycle conditions together, so that their relationship is verifiable. Section 2.5 positions the proposed framework relative to these requirements. The conjunction is formally specified and validated through allow-and-deny test cases and attack cases, whereas its formal

verification and the remaining lifecycle extensions of RQ5 are left for the next stage (Chapters 9 and 10).

The literature review identifies a consistent pattern of fragmentation across existing research. Across the corpus, Req 3 is the least satisfied requirement, while within Req 6, formal assurance alone is provided by 4 studies, argued informally by 9, and absent in 12. The other five Yes grades for Req 6 in Table 2.10 rest on empirical validation.

The review corrects one framing. Multi-party authorisation of patient consent is not absent from the literature, since the full-text coding shows it in six forms. These range from contingency-path joint approval and admission gates to delegated, witness, and custodial thresholds and guardian co-consent at registration, but no reviewed study treats it as a constitutive predicate that every access decision must satisfy together with the identity, policy, and temporal conditions. The gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision.

The review establishes two gaps. The first is a **conjunction gap**, since no study conjoins identity, authority, threshold, policy, temporal, and lifecycle conditions in one decision predicate in which multi-party approval is a standing condition and the patient defines the approving set. The second is an **assurance gap**, since co-existing conditions are neither proved nor tested as an authorisation decision, and any proof covers only a fragment of the predicate. As shown in Figure 2.2, the proposed research addresses both gaps by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object. Each of Req 1 to Req 6 also leaves a requirement-level gap, termed Gap 1 to Gap 6 and stated in Chapter 3, and each gap corresponds to the research question and objective of the same number in Chapter 3.

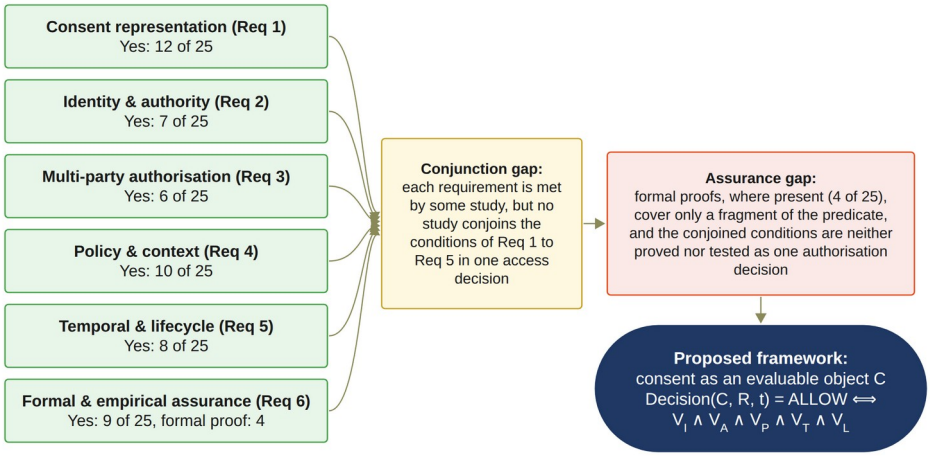


Figure 2.2: Synthesis of the review: the conjunction gap and the assurance gap addressed by the proposed framework, with the number of the 25 analysed studies graded Yes for each requirement in Table 2.10.

As presented in Tables 2.4 to 2.10, researchers have focused on securing individual aspects of healthcare data sharing: recording consent, verifying identity, approving access, and restricting the data that are released. However, from the perspective of the six requirements stated in Section 2.2, the existing work has the following drawbacks:

- *Inability to represent consent as an evaluable authorisation object (Req 1):* Existing consent approaches treat consent primarily as a record of a patient's permission (Akter & Sanam 2025; Prashanth et al. 2024), and some claim consent but leave it out of the access decision (Sawant & Gomes 2026). The evaluable consent objects reported since 2020 (Albalwy, Brass & Davies 2021; Eneh et al. 2026; Phuyal et al. 2026b; Shanmugham & Senthilkumar 2026; Tith et al. 2020) carry only a subset of

the identity, authority, threshold, policy, temporal and lifecycle conditions, and they are issued by a single party. Without such a representation, the existing literature does not allow an access request to be evaluated against the conditions that the patient actually set.

- *Inability to verify authority separately from identity (Req 2):* A valid decentralised identity establishes who a participant is (Mazzocca et al. 2025), but it does not establish what that participant is authorised to do. Authority is verified separately from authentication in only 10 of the 25 studies, and Req 2 is graded Yes in 7 of them (Table 2.10). Without this separation, an authenticated participant is treated as an authorised one.
- *Absence of multi-party approval as a standing condition of every access decision (Req 3):* Multi-party approval appears in the reviewed studies as a contingency path, an admission gate or a registration-time co-consent (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). The approving set is defined on the institutional or delegate side (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024), or it is appointed by the patient but evaluated only as a contingency path or as a key-custody threshold (Maruthi & Singh 2025; Tan, Chi & Lam 2024). Req 3 is the least satisfied requirement, graded Yes in 6 studies (Table 2.10). None of the papers examined makes approval by a patient-defined set a condition of every access decision.
- *Inability to bind purpose and data scope to the same decision as identity, authority and approval (Req 4):* Purpose and data-scope constraints are enforced by 10 of the 25 studies (Table 2.10), but in none of them are they bound to the same decision as identity, authority and multi-party approval; in the reviewed studies, multi-party approval is never conjoined with a purpose condition (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). Without this binding, a valid identity and sufficient approvals can be used to obtain data outside the authorised scope.
- *Absence of temporal and lifecycle evaluation at the time of each access request (Req 5):* Req 5 is graded Yes in 8 of the 25 studies (Table 2.10). In these studies, the validity period, the lifecycle state and the revocation of a consent are enforced on a credential or at registration rather than evaluated when the request is made. Without such evaluation, a consent that has expired or been revoked remains usable once its approvals have been recorded.
- *Absence of formal and empirical assurance of the complete decision (Req 6):* Within Req 6, formal assurance is provided by 4 studies, argued informally by 9, and absent in the rest (Section 2.4.6). The studies that coordinate several mechanisms in one decision (Ferreira et al. 2025; Panagoulias et al. 2026; Phuyal et al. 2026b; Punia et al. 2025; Shanmugham & Senthilkumar 2026) test their own decisions, but none of them proves or tests a conjunction that includes multi-party approval, and any proof covers only a fragment of the predicate. Without such assurance, the correctness of the decision as a whole rests on the correctness of its parts.

The review has limitations. A single search string and a single round of coding mean that a small number of relevant studies may have been missed.

In the next section, we present our proposed framework to address the gaps.

2.5 Trust-Oriented Multi-Party Consent Authorisation Framework

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as

enabling technologies supporting the broader trust model. Sections 2.5.1 to 2.5.6 state how the proposed framework, implemented in the HALAH prototype, addresses each requirement and the research objective that delivers it.

2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)

Consent is represented as the evaluable object C = (I, A, P, T, L, E), created through Algorithm 1 and evaluated at every access request. This requirement is delivered by RO1, presented in Chapter 5.

2.5.2 Decentralised Verification of Identity and Authority (Req 2)

DID and VC verification separates identity from authority and is evaluated as VI through Algorithm 2. The prototype checks the DID format, verifies each guardian's credential before the signature is added, and verifies the requesting doctor's credential at every access request. Full DID resolution is planned for the next stage. This requirement is delivered by RO2, presented in Chapter 6.

2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)

N-of-N approval by the guardian set G with EIP-712 guardian signatures (Bloemen, Logvinov & Evans 2017), evaluated as VA through Algorithm 3. This requirement is delivered by RO3, presented in Chapter 7.

2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4)

Purpose and a non-empty data scope within the consent are evaluated as VP through Algorithm 4. This requirement is delivered by RO4, presented in Chapter 8.

2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)

The validity window VT, revocation, the lifecycle states, and the on-chain revocation on Sepolia are implemented, as specified in Algorithm 5. The SUSPENDED state and the lifecycle transition check are not yet implemented. This requirement is delivered by RO5, presented in Chapter 9.

2.5.6 Verifiable Auditability and Security Assurance (Req 6)

Audit ledger evidence and 46 automated tests, including twelve attack scenarios A1 to A12. The testing part of Algorithm 6 is done. Formal analysis is left for the next stage. This requirement is delivered by RO6, presented in Chapter 10.

2.6 Conclusion

This chapter reviewed the literature on multi-party consent and trustworthy data sharing in healthcare. Six requirements were stated for a trustworthy multi-party consent authorisation: an evaluable consent object, decentralised verification of identity and authority, multi-party authorisation through a verifiable threshold, policy- and context-aware enforcement at the time of access, temporal validity and lifecycle control, and verifiable auditability and security assurance. The literature was searched in seven databases, screened under the PRISMA 2020 statement, and evaluated against six quality questions, and 25 primary studies were analysed in full against the requirements.

The review shows that each requirement is met by some of the studies, but that no study meets them together. Multi-party approval, where it appears, is a contingency path, an admission gate or a registration-time co-consent, not a standing condition of every access decision with an approving set defined by the patient. Purpose and data scope are rarely

bound to the same decision as identity, authority and approval, and temporal validity and revocation are usually enforced on a credential rather than at the time of each request. Where several conditions are combined, the combined decision is neither proved nor systematically tested. These findings form the conjunction gap and the assurance gap. The next chapter states these gaps, the research questions that follow from them, and the objectives of this thesis.

CHAPTER 3

RESEARCH QUESTIONS AND OBJECTIVES

3.1 Introduction

Chapter 2 reviewed the literature on multi-party consent and trustworthy data sharing in healthcare and found that the conditions for a trustworthy access decision exist in the literature but are never joined in one decision that is evaluated at every request, and that where they are joined the decision is neither proved nor tested. This chapter turns that finding into the research problem of the thesis. Section 3.2 states the research gap, first as a whole and then as six requirement-level gaps. Section 3.3 defines the terms used in the rest of the thesis: the patient, the guardian set, the threshold, the requester and the consent object. Section 3.4 states the main research question and the six sub-research questions, and shows that they form one integrated problem rather than six separate ones. Section 3.5 states the six research objectives and the relationship between each objective and its question. Section 3.6 concludes the chapter.

3.2 Gaps in the Literature

From a thorough review of the existing literature documented in Chapter 2, we have identified the following six gaps:

1. There is no existing representation of patient consent that carries the identity, authority, threshold, policy, temporal and lifecycle conditions of access as one evaluable object. Consent is recorded as a permission, and the evaluable objects that exist carry only a subset of the conditions and are issued by a single party.
2. There is no method that verifies the authority of a participant separately from the authentication of that participant within the same access decision, so a valid identity is taken as permission.
3. There is no mechanism by which multi-party approval, with the approving set defined by the patient, is a standing condition of every access decision rather than a contingency path, an admission gate or a registration-time co-consent.
4. There is no enforcement that binds the purpose and the data scope of a request to the same decision as identity, authority and collective approval.
5. There is no evaluation of temporal validity, lifecycle state and revocation at the moment of each access request; where they exist, they are enforced on a credential or at registration.
6. There is no formal definition or systematic testing of the complete authorisation decision under valid, invalid and adversarial conditions; any proof covers only a fragment of it.

3.3 Key Definitions

The patient, as the data subject, may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. The guardian set G is the set of designated participants whose independent approval is required. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties. In the current prototype, the members of G are guardians. Each member of G is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. The threshold N is the number of valid approvals from members of G needed for activation. If the number of valid approvals is below the required threshold N, the consent cannot produce an effective authorisation decision. The authorised doctor D is the requester whose access request R is evaluated against the consent object C.

The consent object against which these questions are evaluated is defined in Equation (3.1), where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence. Within A, the guardian set G and the threshold N define the required approvals. T is the temporal validity window, and L represents the current state of the consent object and its permissible transitions, including whether the consent remains active or has been revoked. This formulation changes the role of consent from a passive record into an evaluable authorisation object.

$$C = (I, A, P, T, L, E) \tag{3.1}$$

3.4 Research Questions

From the systematic literature review documented in Chapter 2, and the shortcomings outlined in Section 2.4.7, it is clear that there are several gaps in the existing literature on trustworthy multi-party consent authorisation for healthcare data sharing.

Based on the identified research gap, the overarching research question is formulated as follows: "**How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?**" The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework. For brevity, SRQ1 to SRQ6 are referred to as RQ1 to RQ6 throughout this thesis.

- **SRQ1 (Trust-Centric Consent Modelling):** How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?
- **SRQ2 (Decentralised Identity and Authority Trust):** How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?
- **SRQ3 (Trustworthy Multi-Party Authorisation):** How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?

- **SRQ4 (Policy- and Context-Aware Access Control):** How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?
- **SRQ5 (Temporal and Lifecycle Trust):** How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?
- **SRQ6 (Formal Security Assurance and Empirical Validation):** How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

3.4.1 Research Questions as an Integrated Problem

The six sub-research questions are not independent technical questions. RQ1 establishes the conceptual object. RQ2 establishes the trustworthiness of the participants. RQ3 then extends this participant-level trust into a collective decision. RQ4 determines whether the resulting authorisation is applicable to the specific data-access request. RQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, RQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly. The integrated authorisation condition can therefore be expressed as Equation (3.2). Here, V_I represents identity and authority validity, V_A collective authorisation validity, V_P policy and contextual compliance, V_T temporal validity, and V_L consent lifecycle validity.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{3.2}$$

A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial. In the prototype, an ALLOW decision additionally requires the exploratory jurisdiction check V_J (Chapter 8) to pass and the Groth16 ZK proof (Groth 2016) to verify, so a request that satisfies the five predicates is still denied when either fails, as in Scenario 4 (Chapter 10) and attack A9 (Chapter 10). Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Thus, RQ6 operates as an assurance layer over the mechanisms established by RQ1–RQ5.

3.5 Research Objectives

The research objectives turn the research gap into concrete research and development activities. The complete research programme consists of six research objectives, corresponding to six research questions.

3.5.1 RO1: Trust-Centric Consent Model

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model incorporates identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made. RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. It defines the information that must be

represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

3.5.2 RO2: Decentralised Identity and Authority Trust

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data.

3.5.3 RO3: Trustworthy Multi-Party Authorisation

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision. The objective is to prevent unilateral authorisation where collective approval is required. The guardian set G, fixed at consent creation, defines which participants are eligible to contribute an approval to the authorisation process. Each participant must submit an approval that can be independently verified through EIP-712 signature recovery. Invalid approvals are rejected and must not contribute to the threshold count. In the current prototype, a valid signature is required from every listed guardian, so the threshold equals |G|, an N-of-N condition demonstrated in the 2-of-2 configuration. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold. RO3 addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

3.5.4 RO4: Policy- and Context-Aware Access Control

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is a non-empty subset of the authorised EMR modules. In the current prototype, the request purpose is taken from the consent, so the purpose check confirms that the consent purpose is a supported healthcare use, while the comparison with a separately declared request purpose is left to the next stage. RO4 directly addresses RQ4 and completes the foundational authorisation model. Together, RO1–RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

3.5.5 RO5: Temporal and Lifecycle Trust

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. RO5 addresses RQ5 and extends the foundational authorisation model into a dynamic consent environment. The current HALAH code already collects a start time and expiry time during consent creation. The prototype records them on-chain as notBefore and expiry within the consent token, enforces the temporal validity window at every access decision through V_T, implements end-to-end revocation, including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. Access can be granted only in the ACTIVE state, and V_L checks this state at every access decision. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied. The remaining work concerns the

SUSPENDED state, the lifecycle transition check, a formal lifecycle model, and hardening these controls and extending them to consent modification, delegation, and guardian-set changes.

3.5.6 RO6: Formal Security Assurance and Empirical Validation

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios. RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The prototype must execute valid consent workflows, and it must also behave correctly when one or more trust conditions are violated. RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype. In particular, 46 automated tests cover signature rejection, proof tampering, credential checks, and twelve attack scenarios, A1 to A12, against the components of C and the contract. All twelve attacks are refused. Preliminary measurements of on-chain cost, confirmation latency, and processing time have been obtained, and a live out-of-jurisdiction request against a consent anchored on the deployed Sepolia contract was refused by the exploratory jurisdiction check of the application (Chapter 8). The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. Although preliminary implementation and scenario-based testing support the current stage findings, the complete formal analysis, through proofs or model checking, and a larger evaluation under load will be conducted as part of next stage works.

3.5.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives, with the status of each objective, is summarised in Table 3.1. The mapping follows the structure of the research programme and maintains a direct correspondence between each research question and its associated objective. RO1 to RO6 are realised in Chapter 5 to Chapter 10 respectively, each in the section presenting the solution for the corresponding research question. Because each research question corresponds to one gap identified in Chapter 2, each objective addresses the gap of the same number, so that RO1 addresses Gap 1 and RO6 addresses Gap 6. Each research question therefore has one research activity, and each objective contributes to the framework. RO1 to RO4 are delivered in this stage, together with their validation and evaluation through the implemented prototype, whereas, as stated in Chapter 1, RO5 is in progress and RO6 is partially completed. Their remaining work is detailed in Chapter 9 and Chapter 10, and its schedule is presented in Chapter 11. The distinction between current stage and next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives.

Table 3.1: Research questions, research objectives, and the status of each objective

RQ	Research objective	Description	Status
RQ1	RO1: Trust-Centric Consent Model	To develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object.	Done
RQ2	RO2: Decentralised Identity and Authority Trust	To develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials.	Done
RQ3	RO3: Trustworthy Multi-Party Authorisation	To develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision.	Done
RQ4	RO4: Policy- and Context-Aware Access Control	To develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.	Done
RQ5	RO5: Temporal and Lifecycle Trust	To extend the trust-oriented framework with temporal validity and consent lifecycle controls.	In Progress
RQ6	RO6: Formal Security Assurance and Empirical Validation	To formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.	Partially completed

3.6 Conclusion

This chapter stated the research problem. The gap found in Chapter 2 is the absence of an integrated model in which identity, authority, multi-party approval, policy, temporal validity and lifecycle state are evaluated together at every access request, with an approving set defined by the patient, and in which that joint decision is formally and empirically assured. The first five requirement-level gaps form the conjunction gap and the sixth forms the assurance gap.

From this gap, one main research question was stated: how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority and policy constraints. The question was divided into six sub-research questions, one per gap, and each sub-research question was matched with one research objective. The six questions are not independent: the first defines the consent object, the second and third establish who may take part and how they decide together, the fourth and fifth decide whether a particular request is allowed now, and the sixth assures the whole. The next chapter presents the research methodology and an overview of the solution proposed for each question.

CHAPTER 4

RESEARCH METHODOLOGY AND SOLUTION OVERVIEW

4.1 Introduction

Chapter 3 stated the research gap, the main research question, the six sub-research questions and the six research objectives. This chapter explains how the research was carried out and gives an overview of the solution before the detailed chapters. Section 4.2 defines the terms that the solution uses and that Chapter 3 did not define. Section 4.3 presents the selected research methodology, Design Science Research, and shows what each of its stages produced in this thesis. Section 4.4 gives an overview of the solution as one end-to-end workflow, from the creation of a consent to the recording of an access decision. Sections 4.5 to 4.10 give an overview of the solution for each research question, RQ1 to RQ6, and name the chapter in which each solution is presented in full. Section 4.11 concludes the chapter.

4.2 Key Definitions

The following terms are used in the overview of the solution and in the chapters that follow. The patient, the guardian set G, the threshold N, the authorised doctor D, the access request R and the consent object C were defined in Chapter 3.

Trust predicate. A condition that must hold before access is allowed, evaluated as true or false at the time of the request. The framework has five: VI for identity and authority, VA for collective authorisation, VP for policy and context, VT for temporal validity and VL for the lifecycle state.

Decision function. The rule Decision(C, R, t) that returns ALLOW only when all five trust predicates hold for the consent C, the request R and the time t, and DENY otherwise. It was stated as Equation (3.2).

Approval. A signed statement by one guardian that approves one consent. An approval is valid only when it is signed by a member of G who has not already approved the same consent.

Verified approving set Av. The subset of G whose approvals have been verified. The consent becomes active when |Av| reaches N.

Lifecycle state. The state of a consent at a point in time: pending until the guardians have approved, not started before its start time, active while it can release data, and expired or revoked when it no longer can.

Audit event. A record written to the audit ledger for every action on a consent, including its creation, each approval, each access decision with the result of the five predicates, and its revocation.

Scenario. One complete run of the prototype that exercises a defined path, such as the creation and approval of a consent followed by an allowed request, or a request made after revocation.

Attack scenario. A deliberate attempt to obtain access while one of the trust conditions is not satisfied, such as an approval from a signer outside G or a request outside the authorised data scope. The framework must refuse every attack scenario.

Prototype. The HALAH implementation of the framework, used to show that the design can be built and to evaluate it against the scenarios and attack scenarios.

4.3 Selected Research Methodology

This research follows the Design Science Research (DSR) methodology, based on the process model of Peffers et al. (2007), as shown in Figure 4.1. DSR fits this research because its aim is to design and evaluate an artefact, the trust-oriented authorisation framework and its HALAH prototype, that addresses an identified problem. The process has five stages. Knowledge gained in each stage feeds back into the process through iteration, so that the design is refined over successive cycles.

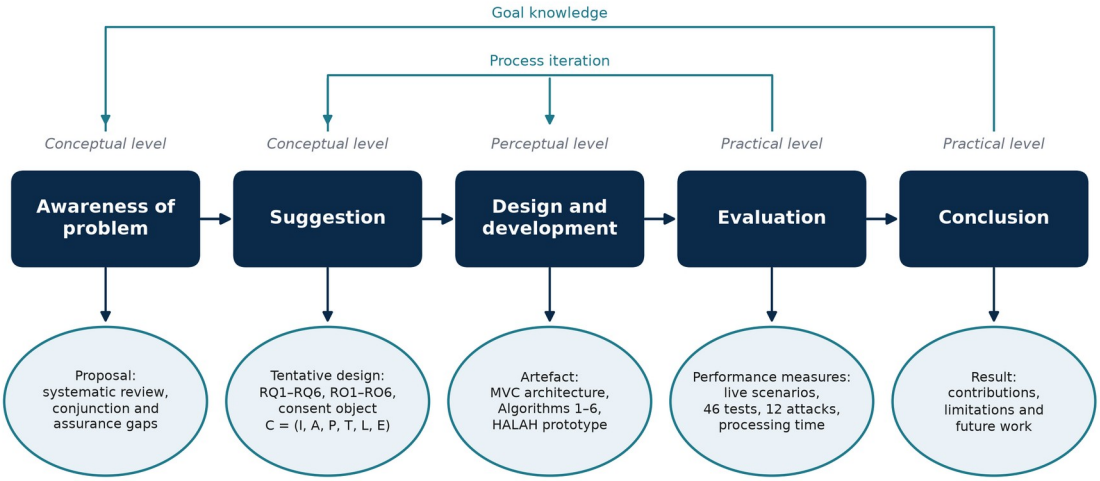


Figure 4.1: The Design Science Research process of this thesis, with the output of each stage, adapted from Peffers et al. (2007).

In the awareness-of-problem stage, the systematic literature review of Chapter 2 identified the fragmentation of trust conditions in existing consent mechanisms, and its output is the research proposal. In the suggestion stage, the research gap was turned into the research questions RQ1 to RQ6, the research objectives RO1 to RO6, and the integrated trust model, which together form the tentative design. In the design and development stage, the consent object C, the MVC architecture, and Algorithms 1 to 6 were designed, and the HALAH artefact was implemented on the Sepolia testnet (Chapters 5 to 10). In the evaluation stage, the artefact was evaluated through access scenarios, 46 automated tests including twelve attack scenarios, and measurements of gas and processing time, which provide the performance measures (Chapter 10). In the conclusion stage, the results, the contributions, and the remaining lifecycle and assurance work are reported.

4.4 Solution Overview

The framework is best understood as one workflow that starts when a patient creates a consent and ends when an access decision is recorded. This section presents that

workflow and the two conditions that govern the collective authorisation step. The architecture that carries the workflow is presented in Chapter 5.

Figure 4.2 presents the end-to-end workflow of the proposed framework. The workflow begins when the patient creates a consent request. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorise and provides the policy context against which subsequent access requests can be evaluated. The next step of the workflow applies a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The framework separates identity authentication from authorisation. A successfully verified DID or VC does not, by itself, grant permission to access patient data. The framework then collects the participants' independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let A_v denote the set of participants whose approvals have been verified and let N denote the required authorisation threshold, as in Equation (4.1). Here, Token(C) $\neq \emptyset$ means that C has been assigned a token identifier, and Revoked(C) $= 0$ means that the consent has not been revoked.

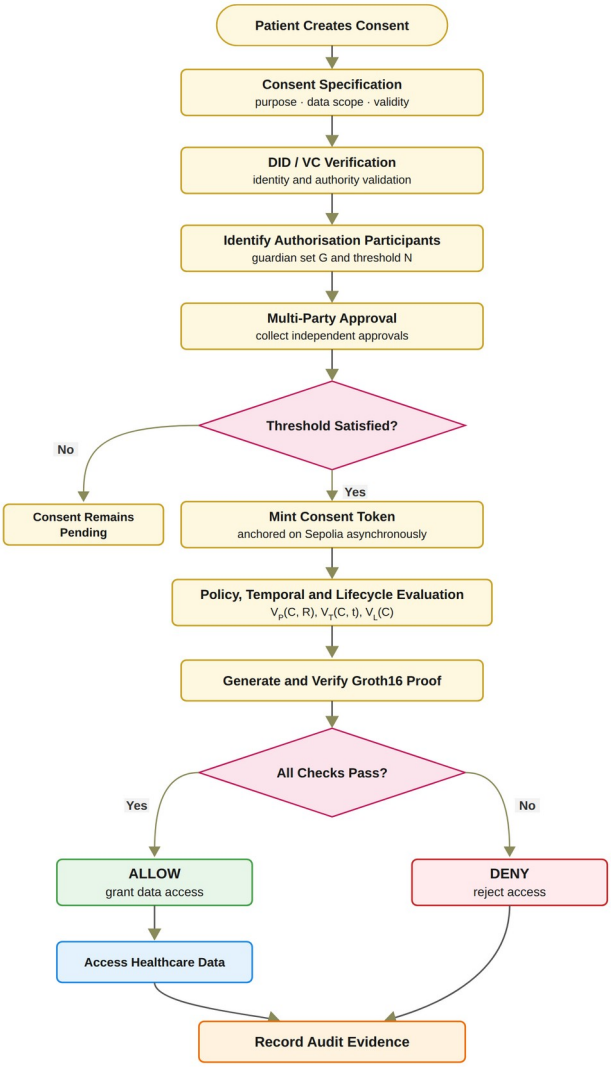


Figure 4.2: End-to-end workflow of the trust-oriented consent authorisation framework.

$$V_A(C) = 1 \text{ if } |A_v| \geq N \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0, \text{ and } 0 \text{ otherwise.} \quad (4.1)$$

Only independently verified participants can contribute to the set of verified approving participants A_v, as defined in Equation (4.2), where A_s denotes the set of approvals submitted for C. A_v therefore contains each member of G at most once, and an approval from a signer outside G does not enter A_v. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. This distinguishes the framework from reviewed systems in which joint approval is a contingency path, a witness or notary threshold, a registration-time co-consent, a documentation-time gate on guardian access, an institution-side admission gate, a custodial M-of-N signature, a key-share reconstruction, or a threshold proxy re-encryption.

$$A_v = \{g \in G \mid \exists\, a_i \in A_s \text{ submitted by } g \text{ with } V_I(g) = 1\}. \tag{4.2}$$

In the implemented prototype, the threshold is fixed at $N = |G|$, as justified in Chapter 7, and once the N-of-N condition is satisfied, the consent token is minted in the local ledger and a background job anchors the mint on Sepolia asynchronously. The policy, temporal and lifecycle checks V_P, V_T and V_L, together with the exploratory jurisdiction check V_J, are then evaluated, a Groth16 proof is generated and verified before access is granted, and the audit evidence is recorded. Beyond the access decision shown in Figure 4.2, the prototype continues through patient-initiated revocation and the corresponding on-chain revoke transaction, after which the auditor reviews the record and the verification tool performs an independent verification. If the required threshold is not satisfied, the consent remains pending, and any access request made against it is denied. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses a limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent authorises access to observations and medications, a request for observations, medications, and procedures should be rejected because the request exceeds the authorised data scope. Similarly, the purpose must be a supported healthcare use. The full design also requires the requested purpose to match the purpose recorded in the consent, which the prototype does not yet compare, as Chapter 8 explains. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. Both successful and denied decisions should be recorded because a trustworthy authorisation framework requires accountability not only for data that were released but also for access attempts that were rejected. In the prototype, every denial, including one against a consent that is not ACTIVE, is recorded with its complete decision matrix.

4.5 Overview of Solution for RQ1

RQ1 asks how patient consent can be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints and authorisation evidence. The solution is the trust-centric consent model of RO1, in which consent is no longer a stored record of permission but the object $C = (I, A, P, T, L, E)$ that every access request is evaluated against. I carries the identity of the patient, the doctor and the guardians; A carries the authority requirements, the guardian set G and the threshold N; P carries the purpose and the data scope; T the validity window; L the lifecycle state; and E the evidence of every decision taken on the consent.

The consent object is created through Algorithm 1. The patient selects the doctor, names the guardians, chooses the data modules, states the purpose and sets the start and expiry dates. The system validates each field, assigns a unique consent identifier, sets the state to PENDING_SIGNATURE, sets N to the number of guardians, persists the object and records the creation event in the audit ledger. From that point the consent can be

evaluated, not merely looked up. The model, the algorithm and its realisation in the HALAH prototype are presented in Chapter 5, together with the research architecture that carries it.

4.6 Overview of Solution for RQ2

RQ2 asks how decentralised identities and verifiable credentials can establish trustworthy participants while separating identity authentication from authorisation authority. The solution is the identity and authority verification mechanism of RO2. Every participant holds a decentralised identifier, and every participant who takes part in a decision holds a verifiable credential issued by a trusted issuer that states their role. When a guardian approves or a doctor requests data, the framework checks the identifier and then the credential: the signature must verify, the issuer must be in the registry of trusted issuers, the subject of the credential must be the identifier presented, the current time must lie inside the validity period, and the role must be the one the step requires. A doctor must also be the doctor named in the consent.

The result is the predicate VI. A valid identity with no credential, or with a credential of the wrong role, fails VI and is refused before any other check. This is what separates who the participant is from what the participant may do. The verification model, Algorithm 2 and its realisation are presented in Chapter 6.

4.7 Overview of Solution for RQ3

RQ3 asks how multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to authorise access on their own. The solution is the multi-party authorisation mechanism of RO3. The patient fixes the guardian set G and the threshold N when the consent is created. Each guardian signs an approval over the consent identifier and their own identifier, so an approval cannot be moved to another consent. Only approvals from distinct members of G whose credentials verify enter the verified approving set Av; an approval from a signer outside G, or a second approval from the same guardian, does not advance the count.

The consent stays pending, and releases no data, until |Av| reaches N. In the prototype every listed guardian must approve, so N equals |G|. Once the threshold is reached the consent becomes active and a token is recorded as evidence, and the approvals are checked again, as VA, at every later request. The mechanism, Algorithm 3 and its realisation are presented in Chapter 7.

4.8 Overview of Solution for RQ4

RQ4 asks how policy, purpose and data-scope constraints can be incorporated into the authorisation decision so that valid identities and sufficient approvals cannot be used to obtain data outside what the patient allowed. The solution is the policy- and context-aware access control of RO4. The consent carries the purpose and the set of data modules the patient authorised. When a doctor requests data, the predicate VP checks that the purpose is a supported healthcare use and that the requested modules form a non-empty subset of the authorised modules. A request for observations, medications and procedures against a consent that allows observations and medications is refused, although the requester is the right doctor and the guardians have approved.

VP is therefore the condition that makes identity and approval necessary but not sufficient. The policy model, Algorithm 4 and its realisation are presented in Chapter 8.

4.9 Overview of Solution for RQ5

RQ5 asks how temporal validity and lifecycle controls can ensure that an authorisation remains valid only within its permitted time interval and lifecycle state. The solution is the temporal and lifecycle trust of RO5. The consent carries a start time and an expiry time, and the predicate VT checks at every request that the request time lies between them. The consent also has an explicit lifecycle: it is pending until the guardians have approved, active while it can release data, and expired or revoked afterwards. The patient can revoke an active consent at any time. The predicate VL checks at every request that the state is active, so a consent that has expired or been revoked cannot be used, whatever approvals it once held.

Because VT and VL are evaluated at the time of each request rather than once at registration, a change in the consent takes effect on the next request. The lifecycle model, Algorithm 5 and its realisation are presented in Chapter 9.

4.10 Overview of Solution for RQ6

RQ6 asks how the security properties of the authorisation mechanism can be formally defined and empirically evaluated to show that the implemented framework enforces authorised and unauthorised decisions correctly. The solution of RO6 has two parts that complement each other. The formal part defines the security properties of the integrated decision, authorisation integrity, threshold authorisation security and lifecycle safety, and states the assumptions under which they are analysed. The empirical part evaluates the HALAH prototype through scenarios in which the expected and the observed decisions are compared, and through attack scenarios in which each trust condition is deliberately bypassed. Algorithm 6 defines this validation procedure, and Chapter 10 presents the formal properties, the prototype, the scenarios, the measured results and the attack scenarios.

4.10.1 Testing and Verification of the Solution

The prototype is tested at three levels. Live scenarios run the whole workflow through the web interface: a consent is created, each guardian approves, the authorised doctor is allowed, a request that does not satisfy the conditions of the consent is refused, and a request after revocation is refused. Automated tests, 46 in all, check each predicate on its own and together, including twelve attack scenarios, A1 to A12, in which a signer outside G, a replayed signature, a duplicate approval, an over-scope or empty request, a request outside the validity window, a request after revocation, a tampered proof and a forged credential are each refused. The processing time of each check is measured so that the cost of the decision is known. Every decision, allowed or refused, is written to the audit ledger with the result of the five predicates, and the ledger is the evidence used in Chapter 10.

4.11 Conclusion

This chapter presented the research methodology and an overview of the solution. The research follows Design Science Research: the systematic review produced the proposal, the research questions and objectives and the consent model formed the tentative design, the architecture, the algorithms and the HALAH prototype are the artefact, the scenarios, tests, attack scenarios and measured times are the performance measures, and the contributions and remaining work are the result. The solution was then shown as one workflow, from the creation of a consent to the recording of an access decision, and summarised for each research question: an evaluable consent object for RQ1, identity and authority verification for RQ2, multi-party authorisation for RQ3, policy and scope

enforcement for RQ4, temporal and lifecycle control for RQ5, and formal and empirical assurance for RQ6. The next chapter presents the research architecture and the trust-centric consent model in full.

CHAPTER 5

RESEARCH ARCHITECTURE AND TRUST-CENTRIC CONSENT MODEL

5.1 Introduction

In this chapter, firstly the research architecture on which the whole framework is built is presented. There are three layers in the architecture, and the role of each layer is explained in this chapter. Furthermore, a model is proposed to represent patient consent as an evaluable authorisation object; this provides a complete solution to research objective 1. In this chapter, we also present the results of the validation of the proposed solution to research question one. To validate this research question, we built the HALAH prototype and used the following technologies to test the system:

1. **Blockchain:** A blockchain is a decentralised and distributed ledger that records transactions across many computers so that a recorded entry cannot be altered retroactively without altering the blocks that follow it (Wood 2014). In this research, the Ethereum test network Sepolia (Ethereum Foundation 2026b) is used to anchor the state of an approved consent as a soulbound token (Cai 2022) and to record its revocation.
2. **Solidity:** The consent contract is written in Solidity, the contract language of Ethereum (Ethereum Foundation 2026a), and was deployed to Sepolia with the Remix environment (Ethereum Foundation 2026c). The contract stores the start time, the expiry time and the revocation flag of each consent and reports whether the consent is valid at a given time.
3. **Python and Streamlit:** The Controller and the four role interfaces of the prototype, for the patient, the guardian, the doctor and the auditor, are written in Python. The interfaces use the Streamlit library, and the application talks to Sepolia through the web3 library. Consents, approvals, decisions and the audit ledger are kept in a local SQLite database.
4. **EIP-712 and Groth16:** Each guardian approval is a typed-data signature under EIP-712 (Bloemen, Logvinov & Evans 2017), so an approval is bound to one consent, one guardian and one network. The zero-knowledge proof that a consent has not expired is written in circom (iden3 2026b) and is generated and verified with snarkjs (iden3 2026a) under the Groth16 scheme (Groth 2016).
5. **Synthea:** The healthcare records of the prototype are synthetic patients produced by the Synthea generator (Walonoski et al. 2018). The dataset is described in Section 5.7.

The outline of this chapter is as follows. In Section 5.2, we outline the three layers of the architecture and their components. Subsequently, in Section 5.3 we explain where trust is evaluated and where the boundaries between the layers lie, and in Section 5.4 we map the architecture to the six research objectives. In Section 5.5, we present the trust-centric consent model: the creation workflow, the structure of the consent object C = (I, A, P, T, L, E), and the creation procedure as Algorithm 1. Furthermore, in Section 5.6, we discuss the aims of engineering the prototype system used for validating the proposed consent model. In Section 5.7, we outline and explain the dataset used for validation purposes. In Section 5.8 we explain in detail in a stepwise manner the working of the prototype for consent creation. Finally, in Section 5.9 we discuss the results obtained from the

validation of the consent model and the evaluation of the architecture, and Section 5.10 concludes the chapter.

5.2 Layered Architecture and Component Decomposition

The proposed research architecture adopts a Model–View–Controller (MVC) design to provide a structured implementation foundation for the trusted multi-party consent management framework. In the proposed framework, MVC does more than separate data, interfaces, and application logic. It is extended to support a separation between the representation of consent, the interaction of independent stakeholders, and the enforcement of security-critical authorisation decisions. A healthcare consent decision may involve patients, guardians, healthcare professionals, and auditors, each of whom may possess different identities, authorities, and responsibilities. Consequently, the system cannot rely on a single user authentication event or a static permission entry to determine whether access should be granted. Instead, the authorisation decision is the result of evaluating independently verifiable security conditions together.

At the highest level, the architecture consists of three complementary layers. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Figure 5.1 illustrates the conceptual relationship among these layers. The protected healthcare data are deliberately positioned outside the three MVC layers as a protected resource whose access is mediated by the Controller rather than directly exposed to the View.

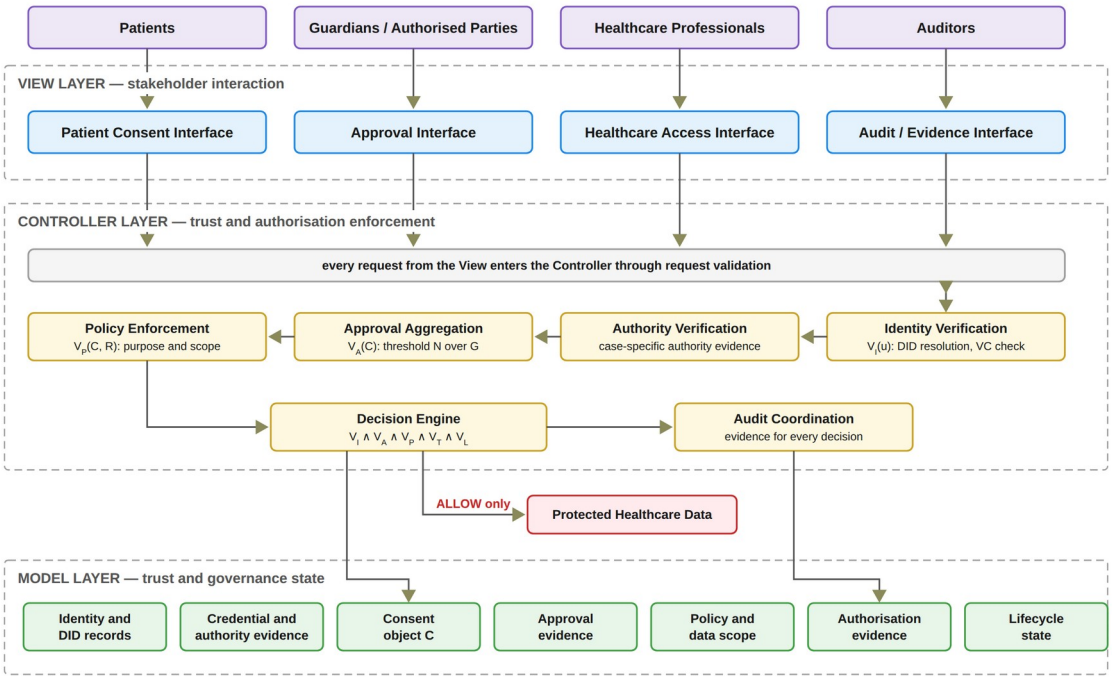


Figure 5.1: Layered MVC architecture and component decomposition of the HALAH framework.

An action submitted through the View represents a request or claim rather than a trusted authorisation outcome. The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include decentralised identity verification, credential and authority verification, multi-party approval evaluation,

policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted. MVC was selected in preference to a purely on-chain design for two reasons. First, the authorisation decision must combine the identity, threshold, policy, temporal, and lifecycle evaluation performed by the Controller with the anchoring of consent state on the blockchain. Second, each stakeholder interface can be replaced without altering the enforcement logic, so the trust predicates are evaluated independently of any particular user interface.

Figure 5.2 presents this decomposition. The View is decomposed according to the principal stakeholder roles. The patient interface supports consent specification and consent-related actions. The guardian or other authorised-participant interface supports independent approval. The healthcare professional interface supports authorised data-access requests. The auditor interface supports inspection of authorisation evidence and audit history. These interfaces represent different interaction responsibilities but share the same architectural principle: none of them independently determines whether access should be granted. The Controller is decomposed into six principal security functions. Identity Verification establishes whether a participant can be identified through the relevant decentralised identity mechanism. Authority Verification evaluates whether the participant possesses appropriate evidence concerning the required role or authority. Approval Aggregation determines whether independently verified approvals satisfy the predefined threshold. Policy Enforcement evaluates whether the requested purpose and data scope comply with the consent policy. Decision Engine combines the resulting predicates into the final authorisation decision. Finally, Audit Coordination records the relevant evidence and decision events. The Model is decomposed into seven principal state representations: DID, VC, Consent, Approval, Policy, Evidence, and Lifecycle. This decomposition establishes an explicit distinction between state, interaction, and enforcement.

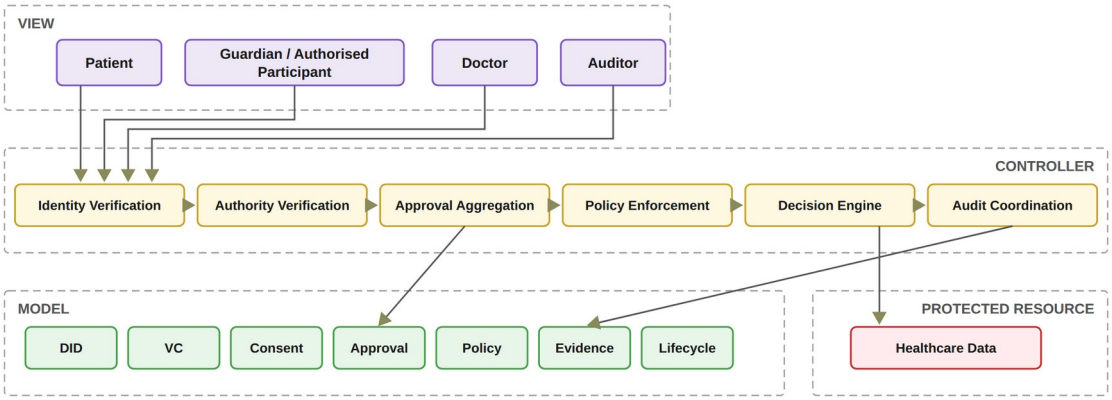


Figure 5.2: Functional decomposition of the MVC components.

In the implemented prototype, the Controller comprises eight principal functions rather than six, since a zero-knowledge (ZK) Proof Service generates and verifies the Groth16 proof that feeds the Authorisation Decision, and an On-chain Anchor Service anchors the Sepolia mint as a background process. A revoke transaction is sent when the patient revokes a consent, and the patient view waits for its confirmation. The Model correspondingly contains the ConsentSBTv3 soulbound contract deployed on Sepolia together with the application audit ledger, both of which an independent verification tool reads, as described in Chapter 10. In the present prototype, each DID must be well formed, and the doctor and each guardian must hold a valid verifiable credential from a

demo issuer. The guardian's credential is checked before the guardian signs, and V_I combines the doctor's credential check with the EIP-712 verification of each listed guardian's signature. The requester's DID and jurisdiction are declared in the interface rather than authenticated, and wallet-held signing keys, full DID resolution and proof that the user controls the DID are deferred to the next stage. However, each guardian approval is an EIP-712 typed-data signature bound to the consent identifier, so the multi-party threshold is enforced over signed approvals rather than over interface actions.

5.3 Trust Evaluation and Architectural Boundaries

The architectural layers cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. A healthcare data-access request is not evaluated according to a single authentication event. As illustrated in Figure 5.3, the Controller coordinates a sequence of trust predicates representing the conditions established by the sub-research questions. The first condition, $V_I(u)$, determines whether the requesting participant possesses valid identity and authority evidence. The second condition, $V_A(C)$, determines whether the required independently verified participants have collectively satisfied the authorisation threshold N. The third condition, $V_P(C, R)$, determines whether the requested operation complies with the consent policy, including purpose and data-scope restrictions. The fourth condition, $V_T(C, t)$, determines whether the consent remains valid at the time of the request. The fifth condition, $V_L(C)$, determines whether the consent remains in a valid lifecycle state. The integrated decision can therefore be expressed as Equation (5.1). In the current prototype, the Consent Engine derives the lifecycle state, a request proceeds only when this state is ACTIVE, and the revocation flag and the token are also checked within V_A. The prototype interface also shows a check labelled VL, which compares the jurisdiction declared in the request with the jurisdiction recorded in the consent. This thesis denotes that check V_J and treats jurisdiction as a contextual policy condition for the next stage (Chapter 8).

Equation (5.1) states that a request is allowed only when every one of the five conditions holds at the time of the request. Conversely, the failure of any one condition is sufficient for refusal, as Equation (5.2) states, and the success of the other conditions cannot compensate for it.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{5.1}$$

$$\neg(V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow \text{Decision}(C, R, t) = \text{DENY}. \tag{5.2}$$

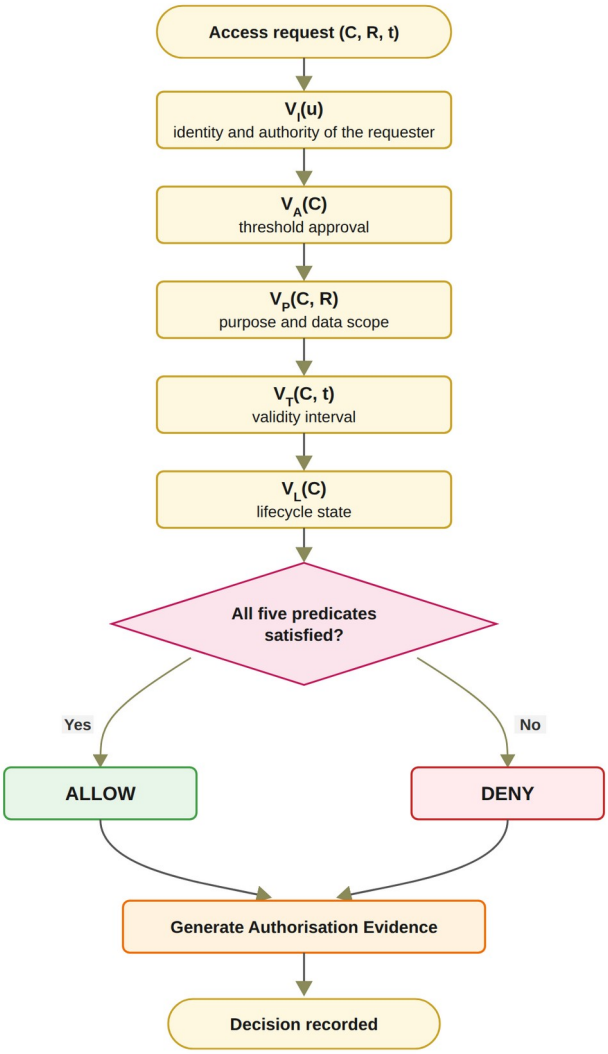


Figure 5.3: Trust predicate evaluation and authorisation decision flow.

If any required predicate evaluates to false, the decision is DENY. The Controller does not itself create these trust conditions. Instead, it evaluates evidence represented by the Model and coordinates the resulting decision. For the interpretation of the architecture: the Controller is a decision-enforcement mechanism, whereas the Model is a representation of trust and governance state. Both successful and unsuccessful decisions are subsequently associated with authorisation evidence, which supports accountability and subsequent verification. The layered architecture also establishes explicit trust boundaries. The View is considered an interaction boundary and therefore cannot be treated as a trusted source of authorisation decisions. The Controller represents the security enforcement boundary. It is responsible for applying the authorisation rules consistently and for preventing direct access to protected healthcare data when the required trust conditions are not satisfied. The Model represents the security-state boundary. Its records provide the evidence and state required for authorisation evaluation, but stored state alone does not constitute permission. In particular, the presence of a consent record, credential, or approval record cannot independently produce an access decision. The protected healthcare data represent the final resource boundary, and access is permitted only through the authorisation path enforced by the Controller. The proposed framework does not claim that MVC itself provides security. Instead, security arises from the explicit placement of trust-sensitive operations within the Controller, the structured representation of security state within the Model, and the

prevention of direct security decisions at the View layer. In the present prototype, the Controller is a single trusted server that both evaluates the predicates and writes the audit ledger, and accordingly, the on-chain anchoring of consent state and the independent verification tool provide the external evidence against which the Controller's own records can be checked. Figure 5.4 puts the same conditions in the order a request meets them. A DID answers who is asking, a verifiable credential and a signed approval answer what that participant may do, the threshold answers whether the members of G agreed, and the policy, temporal and lifecycle checks with the zero-knowledge proof answer whether the consent is still valid for this request. The figure also states, gate by gate, what the current prototype checks, so the reader can see where the design and the prototype differ before the detailed sections.

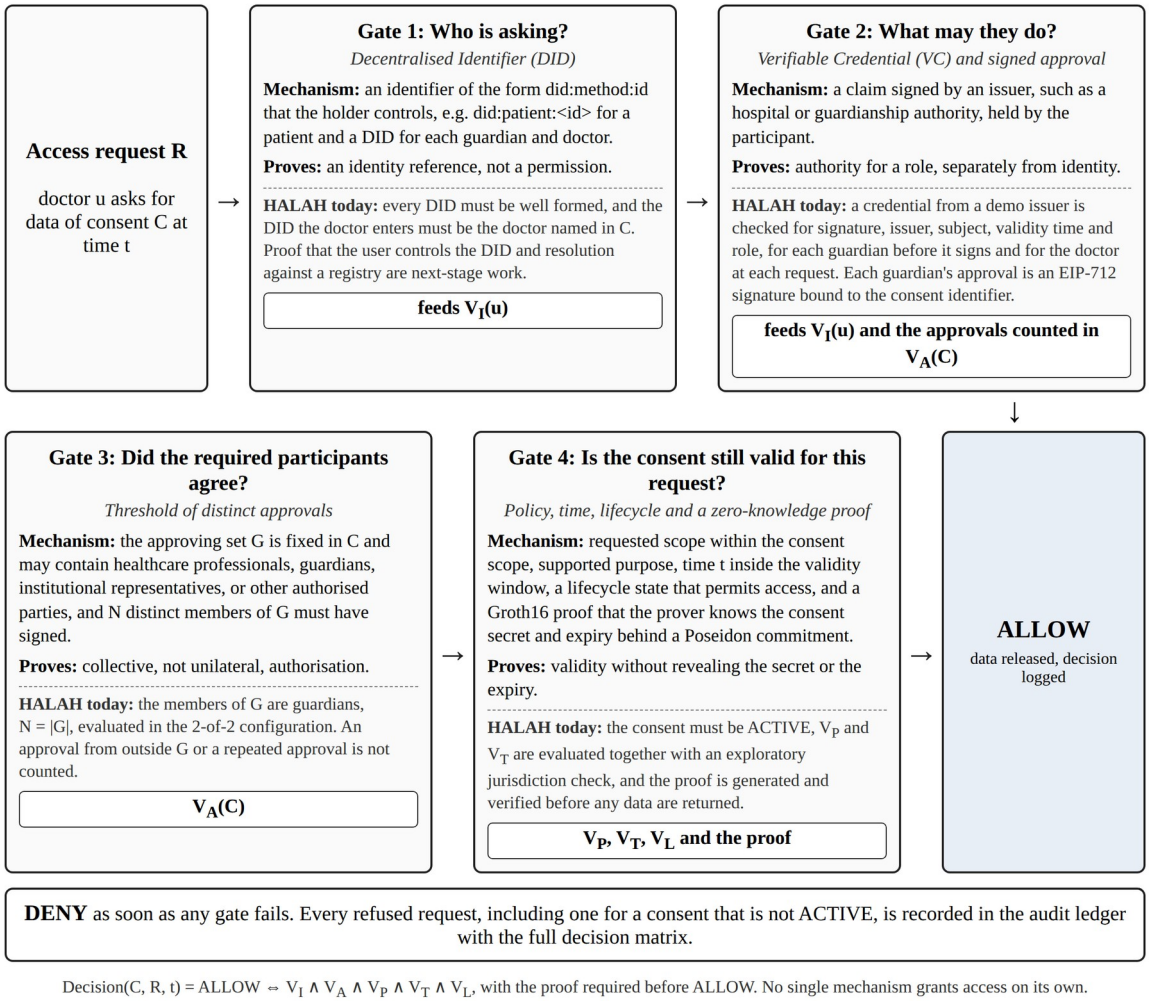


Figure 5.4: The four gates that an access request passes before data are released.

5.4 MVC Architecture and the Research Objectives

The MVC architecture also provides a direct implementation structure for the research objectives, as summarised in Table 5.1. RO1 is primarily represented in the Model through the development of the trust-aware consent object C = (I, A, P, T, L, E). RO2 is implemented through the identity and authority verification mechanisms coordinated by the Controller. RO3 is realised through the multi-party approval and threshold evaluation process. RO4 is implemented through the policy evaluation mechanisms that constrain the authorised purpose and healthcare data scope. For RO5, temporal conditions and lifecycle state are represented in the Model, while V_T and V_L are

evaluated by the Controller before an access decision is produced. RO6 operates across the complete architecture rather than being confined to a single MVC layer. Formal security assurance evaluates the logical properties of the integrated model, while empirical validation evaluates whether the implementation consistently realises those properties. The evidence generated by the Controller and stored in the Model is what the empirical validation and the independent verifier examine.

Table 5.1: Mapping between research objectives and MVC components

Research Objective	Primary MVC Component	Core Mechanism	Expected Contribution
RO1	Model	Trust-aware consent representation	Transforms consent from a passive permission record into a structured and evaluable authorisation object.
RO2	Controller and Model	DID and VC verification	Establishes trustworthy participants while explicitly separating identity from authorisation authority.
RO3	Controller	Verified multi-party threshold evaluation	Establishes collective trust and prevents unilateral authorisation when multiple approvals are required.
RO4	Controller and Model	Policy, purpose, and data-scope evaluation	Ensures that valid participants and sufficient approvals remain constrained by the authorised purpose and healthcare data scope.
RO5	Model and Controller	Temporal validity and consent lifecycle enforcement	Ensures that authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.
RO6	Model, View, and Controller	Formal security analysis and empirical validation	Will provide formal assurance (next stage) of the defined trust and authorisation properties and empirically evaluate whether the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions.

Table 5.2 summarises how the proposed framework differs from traditional EHR access control.

Table 5.2: Traditional EHR access control compared with the HALAH framework

Aspect	Traditional EHR access control	HALAH framework
Identity	Central identity provider; institution login	A DID for every participant; identity kept separate from authority
Consent	A stored record that permission was given	An object C = (I, A, P, T, L, E), checked at every request
Approval	A static permission set by one party	All listed guardians sign (EIP-712); no single party can approve alone
Access check	Log in, then check a static permission	VI ∧ VA ∧ VP ∧ VT ∧ VL, plus a Groth16 proof before data is released
Time and revocation	Hard to verify once the permission is stored	Validity window and revocation checked each time; on-chain revoke
Audit	A record that consent occurred	Every access decision, allowed or denied, logged off-chain with its decision matrix; consent state anchored on Sepolia

The contribution of the proposed architecture is the way MVC is used to carry a trust-oriented authorisation model, not the use of MVC itself. This design transforms multi-party consent management from a conventional record-management problem into a distributed security-governance problem. The evaluable consent object as such is already present in the literature. The key innovation is that consent effectiveness depends on the joint satisfaction of identity, authority, collective approval, policy, temporal, and lifecycle conditions on every access decision. Blockchain or other tamper-resistant storage mechanisms are integrated as infrastructure for preserving selected authorisation evidence. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process. The detailed solutions for RQ1 to RQ6 are presented in Chapters 5 to 10, and the formal assurance of the complete decision model remains for the next stage. The next section presents the solution for RO1, the consent object on which the other objectives build.

5.5 Trust-Centric Consent Model

This section presents the solution for RO1. Section 5.5.1 shows the consent creation workflow, Section 5.5.2 defines the structure of the consent object, Section 5.5.3 presents the creation procedure and the algorithm, Section 5.6 describes the aims of the prototype in which the model is realised, Section 5.7 the dataset, Section 5.8 the steps of consent creation, and Section 5.9 validates and evaluates it.

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions. The proposed consent object is represented as Equation (5.3).

$$C = (I, A, P, T, L, E) \tag{5.3}$$

In Equation (5.3), I represents patient and participant identity information, A represents authorisation requirements, P represents policy constraints, and E represents authorisation evidence. T represents the temporal validity window, and L represents the current state of the consent object and its permissible transitions. The temporal component bounds the consent in time, and the lifecycle component states whether the consent can currently be used. The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit. The consent model therefore separates the specification of consent from the final access decision. A consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

5.5.1 Consent Creation Workflow

Figure 5.5 describes the creation of a trust-aware consent object. The process begins with a patient request and ends with a structured consent record that can be verified by subsequent authorisation services. The workflow first collects the patient identity and the intended healthcare participants. It then specifies the purpose and data scope of the consent. In the HALAH implementation, the patient interface allows the patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent. In the current interface, the purpose is fixed to Treatment and is not selected by the patient, and the

purpose vocabulary check is therefore exercised by the automated tests rather than by the interface.

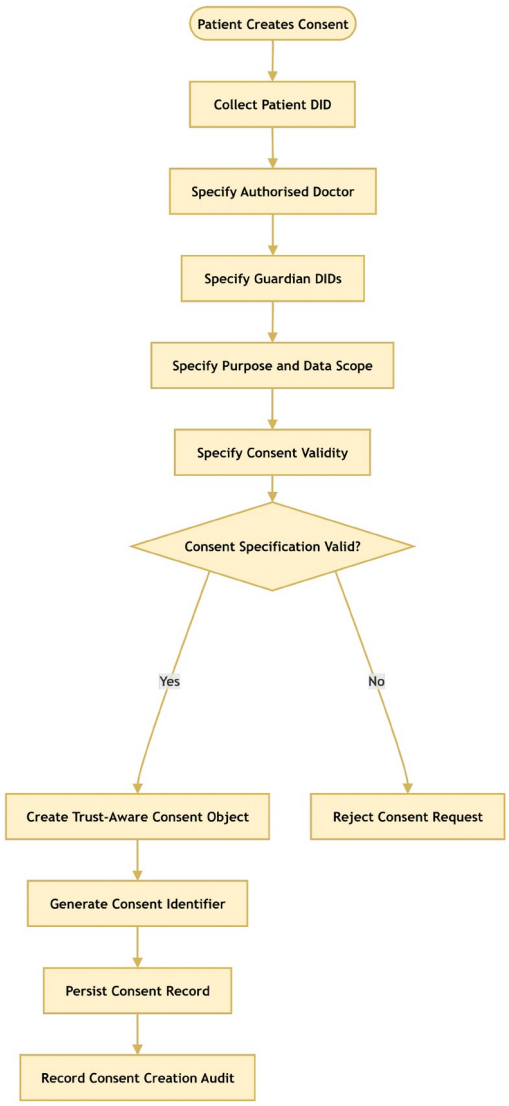


Figure 5.5: RO1 workflow for trust-centric consent creation.

The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time, the data scope must not be empty, and each guardian DID must be well formed. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. This process ensures that the consent object contains sufficient information for subsequent identity verification, multi-party authorisation, policy evaluation, and auditability. Once the consent object is created, its lifecycle state L becomes PENDING, because the consent cannot produce an effective authorisation decision until the required approvals have been obtained. In the current prototype, this state is PENDING_SIGNATURE, and the interface also records a jurisdiction code, AU in the demonstrated transactions, for the exploratory jurisdiction check (Chapter 8).

5.5.2 Structure of the Consent Object

Figure 5.6 shows how the validated information is combined to construct the consent object. The resulting object therefore captures the patient's preference and the evidence needed for later authorisation decisions.

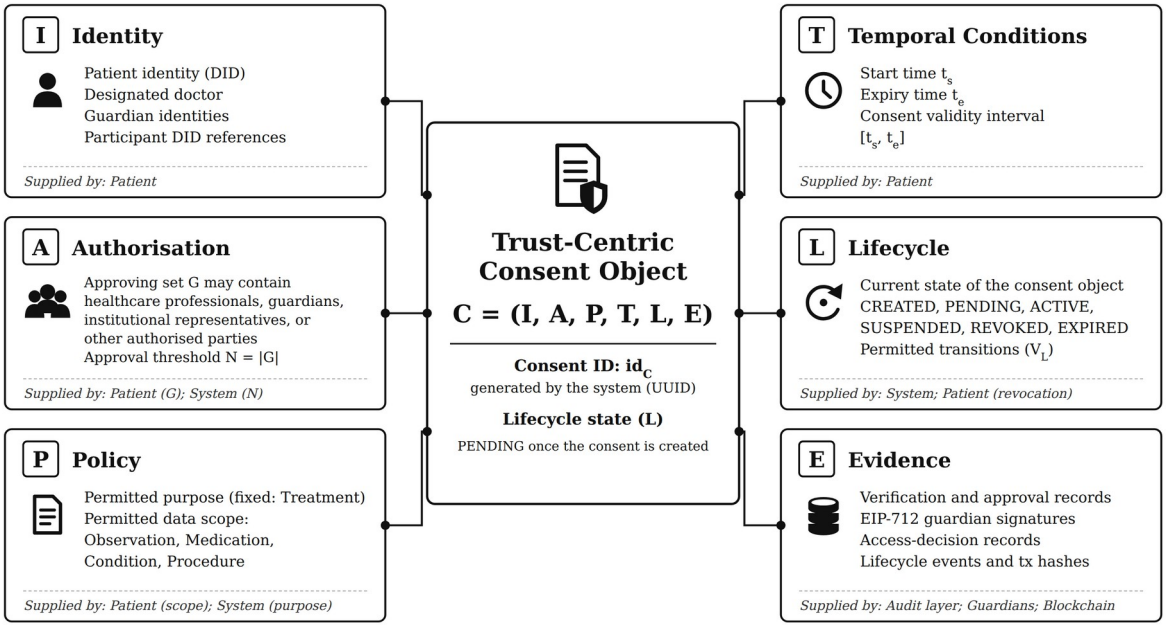


Figure 5.6: Six-component consent model C = (I, A, P, T, L, E).

Unlike the consent objects reported in the literature, this object carries the guardian set and threshold together with the purpose, data scope, validity interval, and lifecycle state.

5.5.3 Trust-Aware Consent Creation Procedure and Algorithm

The Trust-Aware Consent Creation procedure establishes a valid and auditable consent object by sequentially validating the participating entities, consent purpose, data scope, and temporal constraints before the consent is persisted. The procedure consists of the following steps.

Step 1 – Validate Patient Identity. The system first validates the patient's identity Ip. The identity is checked against the available identity and credential verification mechanisms to ensure that the consent request originates from a recognised patient entity. If Ip cannot be successfully validated, the procedure terminates immediately and returns REJECT.
Step 2 – Validate the Authorised Doctor. The system validates the identity and authorisation status of the designated doctor D. This step determines whether the doctor is a recognised healthcare participant and whether the presented credentials are sufficient for participation in the requested consent relationship. An invalid or unauthorised doctor results in rejection of the consent request.
Step 3 – Validate Guardian or Proxy Participants. If a guardian or proxy is specified, the system validates the guardian set G. Each guardian is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. This step prevents an arbitrary third party from being treated as an authorised representative of the patient.
Step 4 – Validate the Intended Purpose. The intended data-use purpose Pu is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies. The purpose is subsequently bound to the consent object so that authorisation is not interpreted as unrestricted access to the patient's healthcare information.
Step 5 – Validate the Data Scope. The requested data scope SC is validated to determine precisely which healthcare resources may be accessed under the consent. The scope may represent specific resource categories, such as observations, medications, procedures, or other resource categories. This step establishes the principle of least privilege by ensuring that consent is associated with explicitly defined data resources rather than the patient's entire healthcare record.

Step 6 – Validate the Consent Validity Interval. The system validates the temporal validity interval $T = (ts, te)$, where ts represents the consent start time and te represents the expiration time. The system verifies that the interval is logically valid by requiring $te > ts$. If this condition is not satisfied, the consent request is rejected.
Step 7 – Define the Authorisation Requirement. After all input elements have been validated, the system defines the authorisation requirement A. This requirement specifies the conditions that must subsequently be satisfied before access can be granted. Depending on the system configuration, A may incorporate patient approval, guardian approval, doctor authority, role requirements, multi-party approval, scope restrictions, purpose restrictions, and temporal constraints.
Step 8 – Generate a Unique Consent Identifier. The system generates a unique consent identifier idC. This identifier provides a persistent reference to the consent object and enables subsequent operations, including consent verification, access authorisation, modification, revocation, and audit.
Step 9 – Construct the Consent Object. The validated information is combined to construct the consent object $C = (I, A, P, T, L, E)$, where I represents the verified identity information, A represents the authorisation requirements, P represents the consent purpose and associated permissions, T represents the validity interval, L represents the lifecycle state, and E represents the evidence associated with the consent decision. The resulting object therefore captures not only the patient's preference but also the evidence required to support subsequent authorisation decisions.
Step 10 – Persist the Consent Object. The constructed consent object C is persisted in the consent-management infrastructure. The persistence mechanism provides a stable representation of the consent state that can subsequently be referenced by the access-control and authorisation components.
Step 11 – Record Consent Creation Evidence. Finally, the system records evidence associated with the creation event, including the consent identifier, participating entities, relevant timestamps, and the resulting consent state. This evidence provides an auditable record that can be used to reconstruct and verify the consent lifecycle.
Step 12 – Return the Consent Result. If all validation and construction operations are completed successfully, the system returns the newly created consent object C. If any mandatory validation fails during the process, the system terminates the procedure and returns REJECT.
The overall procedure can therefore be represented as a sequential trust establishment process that $Ip \rightarrow D \rightarrow G \rightarrow Pu \rightarrow SC \rightarrow T \rightarrow A \rightarrow idC \rightarrow C \rightarrow E$.

This sequence ensures that consent is created only after the relevant identity, authority, purpose, scope, and temporal constraints have been validated. Consequently, the resulting consent object serves not merely as a record of patient preference, but as a structured authorisation artefact that can provide evidence for subsequent healthcare data-access decisions.

Algorithm 1 Trust-Aware Consent Creation

Require: Patient identity I_p, authorised doctor D, guardian set G, purpose P_u, data scope S_C, validity interval T

Ensure: Consent object C or rejection

```
Validate I_p
if I_p is invalid then
    return REJECT
end if
Validate authorised doctor D, guardian set G, purpose P_u and data scope S_C
if any of them is invalid then
    return REJECT
end if
Validate validity interval T = (t_s, t_e)
if t_e ≤ t_s then
    return REJECT
end if
Define authorisation requirement A
Generate consent identifier id_C
Construct C = (I, A, P, T, L, E)
Persist C
Record consent creation evidence
return C
```

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. The consent is placed in the PENDING state (PENDING_SIGNATURE in the prototype), and nothing is anchored on-chain until all guardians approve. The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I, RO3 evaluates the authorisation requirements contained in A, and RO4 evaluates the policy constraints contained in P. Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

5.6 Prototype Implementation

RO1 has been completed at the conceptual and prototype level, and the HALAH patient interface creates the consent object, assigns the identifier, and records the creation event in the audit layer. The main contribution of RO1 is that consent is represented as an evaluable authorisation object rather than as a binary permission. In the current prototype, the patient DID is selected from the loaded record set. The doctor DID and each guardian DID must be well formed and must hold a valid credential for its role, issued by a demo issuer, before the consent is stored, as qualified in Chapter 6. The validation evidence for consent creation, including the demonstration scenarios and the unit-level tests, is presented in Section 5.9.

5.6.1 Aims of Engineering the Prototype System

The primary aim of engineering the prototype system was to simulate the working of the HALAH framework, in which patient consent is created as an evaluable object and every access request is evaluated against it. In particular, in this section, our objective was to use the developed HALAH prototype to test the efficacy of the consent model proposed in Section 5.5: a patient must be able to create the object C = (I, A, P, T, L, E) through an interface, and the object must carry every component that the later checks need. For validating the other objectives of this thesis, we have extended the same prototype (see Chapters 6 to 9).

As discussed in Chapter 2, one of the major challenges of consent management in healthcare is that a stored record of permission does not establish who may act on it, whether every required party agreed, or whether a request stays within the purpose and the data scope that the patient set. With our framework, the consent object carries these conditions, and the prototype makes the design testable: the same code that the interface calls is called by the automated tests, so a check that the interface enforces can also be attacked directly at the service level, which is how the gaps closed by the hardening of 1 October 2026 were found. The prototype also produces evidence: every creation, approval, decision and revocation is written to the audit ledger with the result of each check, so the claims of this and the following chapters can be traced to recorded events rather than to screenshots alone.

We used the Ethereum test network Sepolia as the computing platform for the on-chain part of the prototype, and Solidity as its programming language (Ethereum Foundation 2026a). Sepolia was chosen because it runs the same virtual machine as the Ethereum main network, so the contract and its transactions behave as they would in production, while its ether has no monetary value, which allowed the mint and revoke transactions to be repeated during development. The prototype is not engineered for throughput or for a production deployment; its purpose is to validate the design.

5.7 Datasets Used for Validation

The prototype uses synthetic patient records from the Synthea 1K sample (Walonoski et al. 2018), taken from synthea.mitre.org in its CSV export rather than its FHIR R4 export (HL7 International 2019). Synthea generates realistic but artificial patients, so no real patient data is involved. The Synthea 1K sample is a public synthetic healthcare dataset of 1,000 simulated patient records, with patient demographics, medical conditions, medications and procedures in CSV files. The prototype loads a subset of patients together with their conditions, observations, medications and procedures, and these tables provide the healthcare data modules that a consent can authorise, such as Observation, Medication and Procedure. The records are used only to construct representative consent workflows and the healthcare data-access scenarios used to test the prototype. The authorisation decisions do not depend on the clinical content, and no medical content is written to the chain. The records are not changed. The only step is the selection of the subset loaded into the local database of the prototype.

Table 5.3 shows the Synthea tables loaded by the prototype, the number of records in the loaded subset, and the consent module that each table supplies. The patient DID of the prototype is derived from the Synthea patient identifier, and the records of a patient are selected by that identifier when a consent authorises the module.

Table 5.3: Synthea tables loaded by the prototype and the consent module supplied by each

Synthea table	Records in the loaded subset	Record selected by	Consent module
patients.csv	113	Id (the source of the patient DID)	Patient identity in the patient interface
observations.csv	4,428	PATIENT	Observation
medications.csv	2,931	PATIENT	Medication
conditions.csv	4,748	PATIENT	Condition
procedures.csv	4,237	PATIENT	Procedure

5.8 Steps in the Working of the Prototype System for Consent Creation

In order to create a consent, the HALAH prototype carries out its work at two levels, namely the patient interface and the service layer. In the patient interface, the consent

specification is entered and checked. In the service layer, the consent object is constructed, stored and recorded in the audit ledger. The steps at both levels follow Algorithm 1 and are explained below in Section 5.8.1 and Section 5.8.2 respectively, and Figure 5.7 shows the patient interface after a consent has been created.

5.8.1 Steps in the patient interface

1. The patient selects the role Patient and their own DID, which the prototype loads from the record set.

2. The patient enters the DID of the authorised doctor and the DIDs of the guardians, separated by commas.

3. The patient selects the data modules from Observation, Medication, Condition and Procedure, and sets the start and expiry times.

4. The patient presses Initial Consent. The prototype checks that at least one guardian is listed, that the doctor DID holds a valid doctor credential, that each guardian DID holds a valid guardian credential, that no guardian appears twice, that the data scope is not empty and that the expiry time is later than the start time. If any check fails, an error message names the failed field and nothing is stored.

5.8.2 Steps in the service layer

5. If every check passes, the service layer assigns the consent identifier, stores the object in the state PENDING_SIGNATURE with N set to the number of guardians, writes the CREATE_CONSENT event to the audit ledger, and returns the identifier to the interface, which shows it to the patient.

6. The new consent appears in the patient's list with 0 of N approvals, where it waits for the guardians, whose steps are presented in Chapter 7.

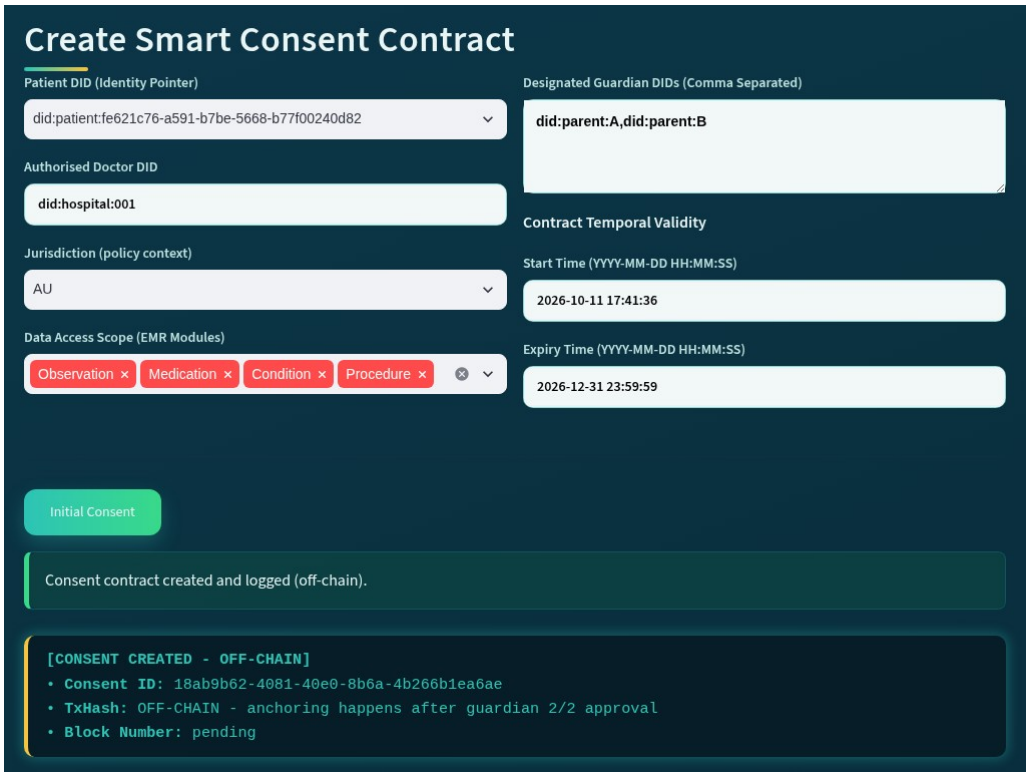


Figure 5.7: The patient interface of the HALAH prototype after a consent has been created.

5.9 Prototype Evaluation and Discussion

Objective one involves the representation of patient consent as an evaluable authorisation object. The result of RO1 is therefore the conceptual model of Sections 5.2 to 5.5, not a set of measurements. The prototype results reported in this section show only that the model can be realised and behaves as specified, so they are reported as outcomes, created or rejected, rather than as numbers; the quantitative evaluation of the complete framework is given in Chapter 10. The results of the validation carried out for this objective are shown in Figure 5.8 and Table 5.4, and the security properties of the architecture are examined in Table 5.5. RO1 is validated in two ways. First, the creation of the consent object is checked functionally: a valid specification must produce a consent object with all six components, and an invalid specification must be rejected before anything is stored. Second, the architecture is evaluated against the security properties it is designed to provide. The validation of the predicates that are evaluated against the consent object, VI, VA, VP, VT and VL, belongs to the chapters of RO2 to RO5, and the evaluation of the complete decision belongs to Chapter 10.

5.9.1 Validation of Consent Creation

Live scenarios. In the demonstration of 24 September 2026, Scenario 1 created the consent f050c29a for a patient with two guardians, did:parent:A and did:parent:B, the authorised doctor did:hospital:001, the four data modules, the purpose Treatment and a validity window ending on 31 December 2026. The audit ledger holds the CREATE_CONSENT event for this consent at 09:50:49 with the result SUCCESS, followed by a second consent, 04da25f5, created at 10:55:49 for another patient. Each creation was followed by the guardian approvals and the access decisions reported in the later chapters, which shows that the created object carried every component that the later checks needed.

Rejected specifications. In the local run of 11 October 2026, three invalid specifications were submitted before the valid one. A doctor DID that does not hold a valid doctor credential was rejected, a guardian DID that does not hold a valid guardian credential was rejected, and a specification that named the same guardian twice was rejected with the message shown in Figure 5.8. Nothing was stored and nothing was logged for the three rejected submissions. The fourth submission, with two distinct guardians holding valid credentials, created the consent 18ab9b62 at 17:41:36, which was then used for the access decisions reported in Chapters 6 to 9.

Automated tests. Two tests cover consent creation. The test test_patient_form_checks_the_doctor_and_the_guardians drives the patient form itself: it submits a malformed doctor DID, a guardian without a credential and a duplicate guardian, and asserts that each is refused with the right message, then submits a valid specification and asserts that the consent is created and logged. The test test_consent_persists_across_reload stores a consent, adds an approval, reloads the store from disk and asserts that the stored object is unchanged. The adversarial test A5 (test_A5_empty_scope_is_rejected) belongs to RO4 but also exercises the creation rule that the data scope must not be empty. All of these tests pass in the suite of 46 reported in Chapter 10.

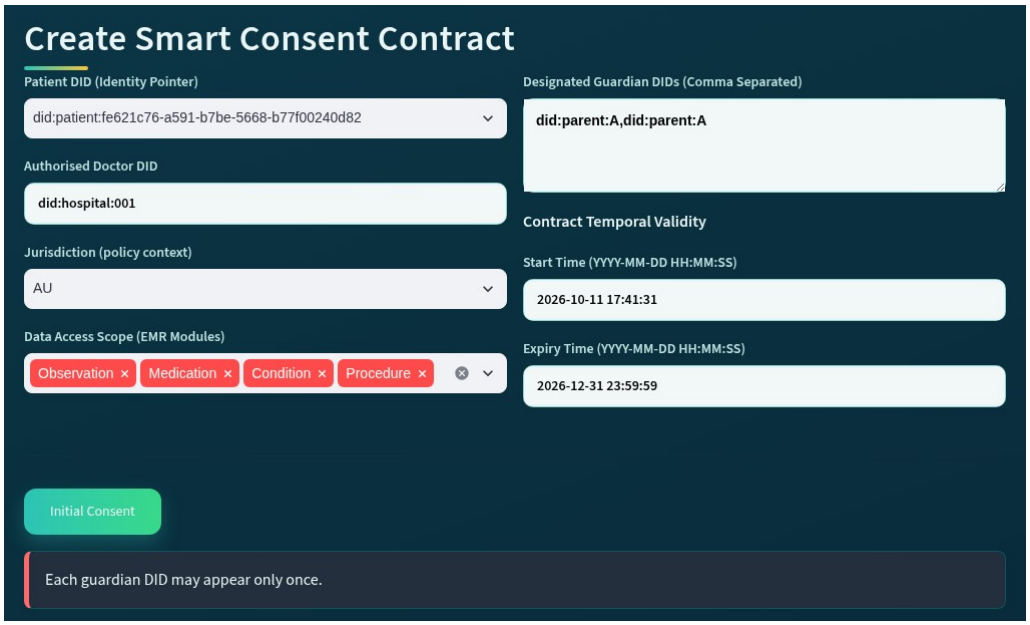


Figure 5.8: A specification that names the same guardian twice is rejected by Algorithm 1 before any consent is stored.

Table 5.4 brings these results together by component of the consent object. For each component of C it gives the check that Algorithm 1 applies at creation, the evidence from the live runs and the automated tests, and the result observed.

Table 5.4: Validation results of the prototype for consent creation

Component	**Check at creation (Algorithm 1)**	**Evidence**	**Result**
I Identity	Steps 1 to 3: the patient identity, the authorised doctor DID holding a valid doctor credential, and each guardian DID holding a valid guardian credential.	Run of 11 October 2026: a doctor DID without a valid doctor credential and a guardian DID without a valid guardian credential were rejected. Test test_patient_form_checks_the_doctor_and_the_guardians.	Invalid identities rejected before anything is stored; valid identities accepted.
A Authorisation	Step 3: the guardian set G and the threshold N; no guardian may appear twice.	A specification naming the same guardian twice was rejected (Figure 5.8). Scenario 1 of 24 September 2026 created consent f050c29a with the two guardians did:parent:A and did:parent:B.	Duplicate guardian rejected; consent created with N set to the number of guardians.
P Policy	Steps 4 and 5: the purpose and the data scope; the data scope must not be empty.	Adversarial test A5 (test_A5_empty_scope_is_rejected). Scenario 1 recorded the four data modules and the purpose Treatment; the purpose vocabulary check is exercised by the automated tests.	Empty scope rejected; purpose and scope recorded in the consent object.
T Time	Step 6: the validity interval T = (ts, te); the expiry time must be later than the start time.	Scenario 1 recorded a validity window ending on 31 December 2026; the prototype refuses an expiry time that is not later than the start time (Section 5.8).	Validity interval recorded; the interval is enforced at every request by VT (Chapter 9).

Component	Check at creation (Algorithm 1)	Evidence	Result
L Lifecycle	Steps 8 and 9: the consent identifier is generated and the object is created in the state PENDING_SIGNATURE.	Consents f050c29a, 04da25f5 and 18ab9b62 were created in PENDING_SIGNATURE. Test test_consent_persists_across_reload: the stored object, including its state, is unchanged after a reload from disk.	Created in PENDING_SIGNATURE; no access is possible until the state is ACTIVE (Chapter 9).
E Evidence	Step 11: the CREATE_CONSENT event is written to the audit ledger with the consent identifier, participants and timestamp.	Ledger events at 09:50:49 (f050c29a), 10:55:49 (04da25f5) and 17:41:36 (18ab9b62), each with the result SUCCESS. Nothing was logged for the three rejected submissions.	Every creation is logged; a rejected specification stores and logs nothing.

5.9.2 Evaluation of the Architecture against the Security Properties

The proposed MVC architecture provides several foundational security properties for the current stage. These properties emerge from the interaction between the Model, View, and Controller rather than from any single technology.

First, the architecture provides identity-dependent participation. A participant cannot contribute to the authorisation process solely by interacting with the system interface. The corresponding identity and credential must satisfy the verification requirements. Second, the architecture provides authority separation. Possession of a valid identity does not automatically result in permission to access patient data. Identity verification provides evidence concerning who an entity is, whereas authority verification determines whether that entity may perform a particular role within the authorisation process. Third, the architecture provides collective authorisation integrity. Sensitive healthcare data access can be configured to require multiple independently verified participants. Therefore, a single participant cannot unilaterally activate access when the defined authorisation threshold has not been reached. Fourth, the architecture provides policy-bounded access. A valid requester with sufficient approval evidence cannot access healthcare information beyond the purpose or data scope defined by the consent object. Finally, the architecture provides decision accountability. The system maintains evidence concerning the conditions that produced an authorisation decision, thereby supporting auditing and subsequent verification. These properties, together with the separation of interaction and enforcement established in Section 5.3, are summarised in Table 5.5, in which collective authorisation integrity and decision accountability appear as multi-party authorisation integrity and authorisation evidence respectively.

Table 5.5: Security properties supported by the proposed MVC-based consent architecture

Security property	Architectural mechanism	Security significance
Identity-dependent participation	DID and credential verification before a participant can contribute to the authorisation process	Designed to prevent unverified entities from being treated as legitimate participants.
Authority separation	Independent evaluation of identity and role or authority evidence	Designed to prevent successful authentication from being interpreted as unrestricted authorisation.
Multi-party authorisation integrity	Threshold evaluation over independently verified approval participants	Designed to prevent a single participant from unilaterally activating sensitive healthcare data access when collective approval is required.
Policy-bounded access	Evaluation of purpose and requested data scope against consent policy	Designed to prevent otherwise valid identities and approvals from being used to obtain data beyond the authorised scope.

Security property	Architectural mechanism	Security significance
Authorisation evidence	Recording of verification results, approval evidence, policy evaluation, and final decisions	Designed to provide traceability and support accountability, auditing, and future verification.
Separation of interaction and enforcement	The View submits requests while the Controller independently determines the security decision	Designed to prevent user-interface actions from being interpreted directly as trusted authorisation outcomes.

Each property in Table 5.5 is realised by a component of the architecture and tested in a later chapter. Identity-dependent participation and authority separation are tested in Chapter 6 through the credential checks and the forged-credential attack. Multi-party authorisation integrity is tested in Chapter 7 through the outside-signer, replayed-signature and duplicate-approval attacks. Policy-bounded access is tested in Chapter 8 through the over-scope and empty-scope attacks. Authorisation evidence is checked in every chapter through the audit ledger and in Chapter 10 through the recorded decisions. Separation of interaction and enforcement is the property that the hardening of 1 October 2026 made real: three attacks that the interface already blocked were also accepted by the service functions until the checks were moved into the Controller, as reported in Chapter 10. The architecture therefore does not claim security from MVC itself; it claims it from the placement of every trust-sensitive check inside the Controller, and the tests of the following chapters are the evidence for that claim.

5.9.3 Discussion

The use of the consent object for consent creation has several advantages which include completeness, rejection before storage, and evidence. Completeness means that a created consent carries every condition that the later checks need, so no check has to look for its condition outside the object. Rejection before storage means that an invalid specification leaves no record behind, so the store never holds a consent that cannot be evaluated. Evidence means that every creation is written to the audit ledger with its identifier, its participants and its time, so the later decisions can be traced back to the consent they were taken on.

On the other hand, the trade-off is rigidity. A consent cannot be changed after it has been created, so a change of doctor, guardian or data scope requires a new consent, and the credentials of the doctor and of every guardian must have been issued before the consent can be created (see Chapter 6). In the current interface, the purpose is also fixed to Treatment. Although these may be considered limitations of the method, the certainty that every stored consent is complete and that every creation is recorded outweighs them at this stage, and consent modification is addressed in the next stage of the research (Chapter 9).

5.10 Conclusion

In this chapter, we discussed the research architecture on which the whole framework is built. In particular, we discussed the three layers of the architecture, where trust is evaluated and where the boundaries between the layers lie, and how the architecture maps to the six research objectives. In addition, we proposed a model to represent patient consent as the evaluable object C = (I, A, P, T, L, E), created through Algorithm 1 only when every field is valid, assigned a unique identifier, persisted in the state PENDING_SIGNATURE and recorded in the audit ledger. This addressed the first research objective of this thesis.

In this chapter we also presented the prototype used for validating the solution to research objective 1. This was done using a public synthetic dataset. At the end of the validation process, the results show that valid specifications are created with all six

components and that invalid ones are rejected before anything is stored, and the architecture was evaluated against the six security properties it is designed to provide. However, a key finding from the validation was that a consent cannot be changed once it has been created; the users of HALAH will have to create a new consent when its terms change.

The next chapter will discuss in a methodological manner the steps involved in verifying who the participants are and what authority they hold, which is the solution for research objective 2.

CHAPTER 6

DECENTRALISED IDENTITY AND AUTHORITY TRUST

6.1 Introduction

In the last chapter, we presented the research architecture and the trust-centric consent model, in which patient consent is created as the evaluable object C = (I, A, P, T, L, E). The identity component I of that object names the patient, the authorised doctor and the guardian set G, but naming a participant does not establish who that participant is or what that participant may do. A key attribute of a trustworthy authorisation decision is that identity and authority are distinct: a participant who can be identified is not thereby authorised, and a participant who holds a credential is not thereby the participant named in the consent (Mazzocca et al. 2025). Hence, it is important that the identity of a participant and the authority that the participant holds are verified as separate conditions before the participant takes part in a consent decision or requests healthcare data.

In this chapter, building on the consent object presented in the last chapter, we present a decentralised method to verify the identity and the authority of a participant. In our work, we use decentralised identifiers coupled with verifiable credentials to model and verify who a participant is and which role the participant holds, and the result of this verification is the predicate VI of the authorisation decision; this provides a complete solution to research objective 2. In this chapter, we also present the results of the validation of the proposed solution to research question two, using the HALAH prototype introduced in Chapter 5.

This chapter is described as follows: In Section 6.2, we provide a detailed explanation of decentralised identifiers, verifiable credentials, and the credential store and trusted-issuer registry of the prototype. In Section 6.3, the principle that identity is not authorisation and the verification condition VI are presented, and Section 6.4 shows the identity and authority verification workflow. Furthermore, Section 6.5 provides the step-by-step procedure and Algorithm 2 required to carry out the verification. Section 6.6 describes how the verification is realised in the prototype and the steps of its working, the proposed solution is validated in Section 6.7, while Section 6.8 concludes this chapter.

6.2 Decentralised Identifiers and Verifiable Credentials

A decentralised identifier (DID) can be defined as a globally unique identifier that is created and controlled by its subject without a central registration authority, and that resolves to a DID document holding the cryptographic material needed to verify the controller of the identifier (W3C 2022). In basic terms, a DID gives a participant an identity reference that no single healthcare institution owns, while a verifiable credential (VC) gives a participant a signed statement about an attribute, such as a professional role, that any party can verify from the signature of the issuer (W3C 2025). Today, DIDs and VCs are being applied in different fields, among them healthcare, education and

government identity, so that a holder can present claims made by one issuer to another verifier (Mazzocca et al. 2025). In this thesis, the two are used together: the DID answers the question of who the participant is, and the VC answers the question of what the participant may do.

6.2.1 Decentralised Identifiers

A DID is a string with three parts separated by colons: the scheme did, the DID method, and the method-specific identifier (W3C 2022). For example, the identifier did:hospital:001 used in the prototype has the method hospital and the method-specific identifier 001. The method defines how an identifier is created, resolved, updated and deactivated. Resolving a DID returns its DID document, which lists the verification methods, such as public keys, by which the controller of the DID proves control of it, and may list the service endpoints at which the controller can be reached (W3C 2022). Figure 6.1 shows this structure.

In this thesis, a DID is the identity reference of every participant. The patient, the authorised doctor and each guardian are named in the consent object by their DIDs, and the DID of a requester is the identity against which the credential of Section 6.2.2 is checked. In the current prototype a DID is checked for its syntax, and the resolution of the DID document is reserved for the next stage, as Section 6.6 explains.

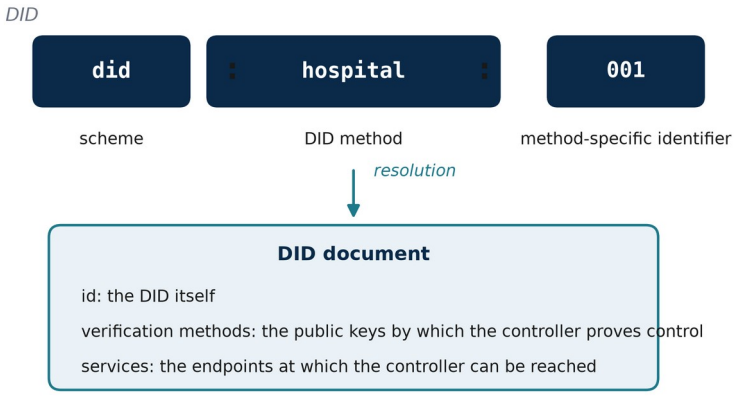


Figure 6.1: Structure of a decentralised identifier and its DID document (after W3C 2022)

6.2.2 Verifiable Credentials

A verifiable credential is a set of claims made by an issuer about a subject, together with a proof that lets a verifier check that the claims were made by that issuer and have not been altered (W3C 2025). Three roles take part. The issuer signs the credential and gives it to the holder, the holder keeps the credential and presents it, and the verifier checks the proof and the claims (W3C 2025). The data model defines, among other properties, the issuer, the validity period validFrom and validUntil, the credentialSubject, which holds the identifier of the subject and the claims about it, and the proof (W3C 2025).

In this study, the credential is a role credential: it states that the subject DID holds the role doctor or guardian and names the organisation of the holder, if any. The credential used by the prototype follows this structure, as Figure 6.2 shows, and its proof is an EIP-712 typed-data signature of the issuer (Bloemen, Logvinov & Evans 2017), so the same signature scheme serves the credentials of this chapter and the guardian approvals of Chapter 7. A credential is taken to be valid only when its signature verifies, its issuer is trusted, its subject is the DID that presents it, and the time of the check lies inside its validity period; the role claim is then compared with the role that the step requires.

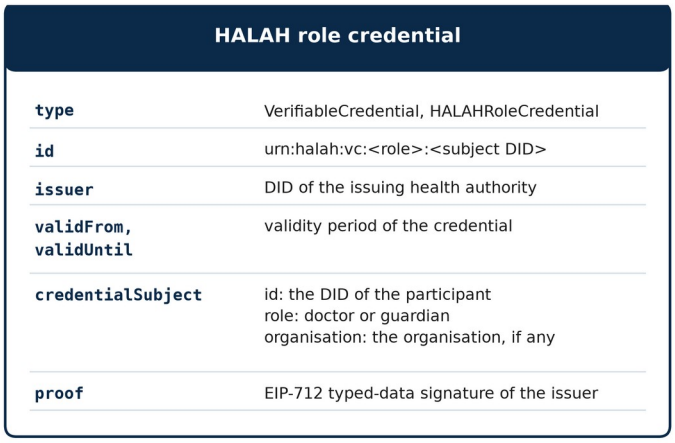


Figure 6.2: Structure of the role credential used by the prototype

6.2.3 Credential Store and Trusted Issuers

The verification of Section 6.5 relies on two stores. The credential store holds the credential of each participant DID and stands in for the wallet of the holder at this stage of the prototype. The trusted-issuer registry maps the DID of each accepted issuer to the address to which its credential signatures must recover. A credential from an issuer that is not in the registry fails the issuer condition, and a credential whose signature recovers to another address fails the signature condition, so the two conditions are checked separately and recorded separately. In the current prototype, the registry holds one demo issuer, did:halah:issuer:demo-health-authority, and the credential store holds the credentials of four guardians and three doctors, from which the two guardians and the two doctors of the demonstrations are drawn. The key of the demo issuer can be reproduced from the source code, so the check demonstrates the verification steps and not the secrecy of the issuer key, as Chapter 5 noted.

6.3 Overview of Decentralised Identity and Authority Trust

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while separating identity authentication from authorisation authority. RO2 provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. The central principle of RO2 is Equation (6.1).

$$\text{Identity} \neq \text{Authorisation}. \tag{6.1}$$

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity and authority verification condition can be expressed as Equation (6.2), where u is the requesting participant and $\text{Authority}(u, C)$ establishes whether the verified authority matches the role required by the consent. The DID verification process establishes whether the identity reference is valid. In the current prototype this check is structural, as Section 6.6 explains. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u) \wedge \text{Authority}(u, C). \tag{6.2}$$

6.4 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent. In the HALAH implementation, the Guardian workflow uses a selected guardian DID and invokes VC verification before adding the guardian's signature to the consent. As shown in Figure 6.3, the output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

Figure 6.3 shows the target design of the workflow. Full DID resolution is planned for the next stage, whereas the current prototype performs a DID-format check, a check of a demo-issuer credential and EIP-712 signature recovery, as Section 6.6 explains.

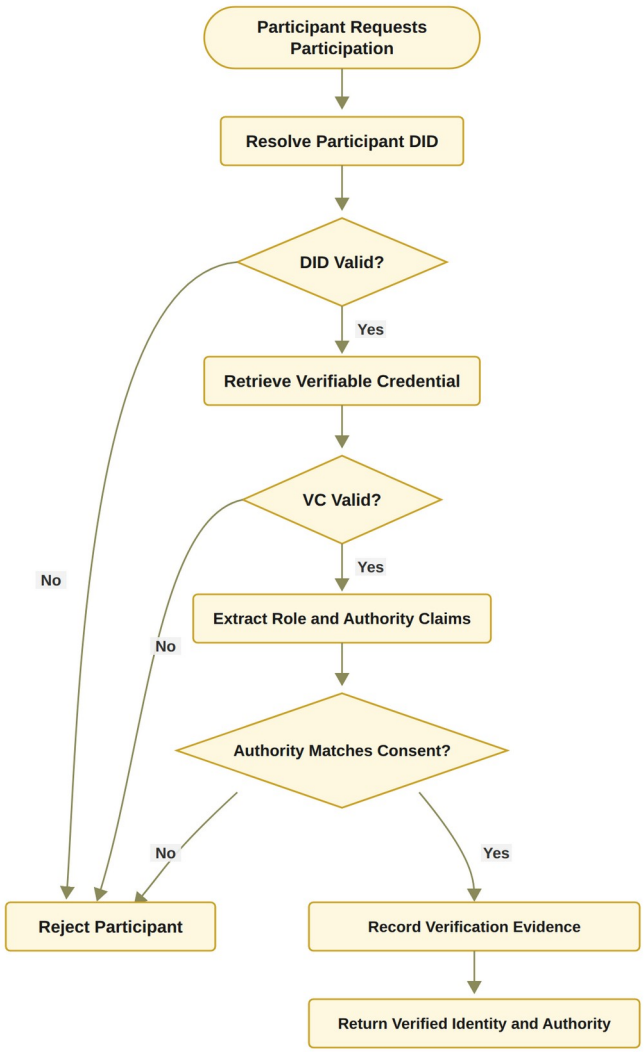


Figure 6.3: RO2 workflow for decentralised identity and authority verification

6.5 Verification Model and Algorithm

The proposed solution to Objective 2 is grounded in the decentralised identifiers and verifiable credentials of Section 6.2. The verification combines three checks, the identifier, the credential and the authority that the credential gives for the consent at hand, into the single predicate VI of Equation (6.2). Section 6.5.1 presents the procedure step by step, and Section 6.5.2 formalises it as Algorithm 2, which the prototype of Section 6.6 implements.

6.5.1 Step-by-Step Procedure for DID and VC Identity and Authority Verification

The procedure below is the one defined for this objective. It is presented in full so that the reader can understand the working of Algorithm 2, which formalises it in Section 6.5.2.

The DID and VC Identity and Authority Verification procedure determines whether a participant possesses a valid decentralised identity and sufficient verifiable authority to participate in the consent-defined authorisation process. The procedure establishes a verifiable relationship between the participant u, the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object C. The procedure consists of the following steps.

Step 1 – Resolve the Participant's DID. The system first resolves the decentralised identifier (DID) associated with participant u. DID resolution retrieves the DID-related information required to establish the participant's decentralised identity and identify the corresponding DID document. If the DID cannot be successfully resolved, the verification process terminates and returns INVALID.
Step 2 – Verify the DID Document. After successful resolution, the system verifies the DID document and its associated identity information. The verification process determines whether the document is structurally valid and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted for subsequent credential verification. A failed DID verification results in an INVALID outcome.
Step 3 – Retrieve the Participant's Verifiable Credential. The system retrieves the verifiable credential (VC) associated with participant u. The VC provides machine-verifiable claims concerning the participant, such as professional role, organisational affiliation, or delegated authority. If an appropriate VC cannot be retrieved, the participant cannot establish the required authority and the verification process returns INVALID.
Step 4 – Verify the Verifiable Credential. The retrieved VC is cryptographically and semantically validated. The system verifies the credential signature, issuer, subject, and validity conditions. In particular, the system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential remains within its validity period. Formally, the credential can be considered valid only when $VC_{valid} = Sig_{VC} \wedge Issuer_{valid} \wedge Subject_{match} \wedge Time_{valid}$. If any of these conditions fails, the verification process returns INVALID.
Step 5 – Extract Role and Authority Claims. Once the VC has been successfully verified, the system extracts the relevant role and authority claims associated with participant u. Depending on the healthcare scenario, these claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims provide the evidence required for determining whether the participant satisfies the authority requirements of the consent object.
Step 6 – Compare Authority Claims with Consent Requirements. The extracted role and authority claims are compared against the authorisation requirements A specified in the consent object C. The purpose of this step is to ensure that possession of a valid identity or credential is not automatically interpreted as permission to access healthcare information. The authority verification condition can therefore be represented as $Authority(u, C) = Claims(u) \models A_C$, where $Claims(u)$ denotes the verified claims associated with participant u, and A_C denotes the authority requirements defined by consent object C. If the participant's claims do not satisfy the required authority conditions, the system returns INVALID.

Step 7 – Establish Identity–Authority Binding. After the claims have satisfied the consent requirements, the system establishes the binding between the verified participant identity and the corresponding authority. This step ensures that the authority being exercised is associated with the same participant whose DID and VC have been successfully verified, thereby reducing the possibility of an unrelated credential being used to obtain access.
Step 8 – Record Identity and Authority Evidence. The system records the evidence generated during the verification process. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, verification timestamp, and the relationship between the verified claims and the consent requirements. This evidence provides an auditable basis for subsequent access-authorisation decisions.
Step 9 – Return the Verification Result. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns $VI(u) = VALID$. Otherwise, the procedure terminates at the first failed mandatory verification condition and returns $VI(u) = INVALID$.
The overall verification process can therefore be represented as $DID_{resolve} \rightarrow DID_{verify} \rightarrow VC_{retrieve} \rightarrow VC_{verify} \rightarrow Claims_{extract} \rightarrow Authority_{match} \rightarrow Evidence_{record} \rightarrow VI(u)$.

The procedure establishes an important separation between identity verification and authority verification. A participant is not considered valid merely because a DID can be resolved or because a VC has a valid cryptographic signature. Instead, the participant must demonstrate that the verified credential claims satisfy the authority requirements associated with the specific consent object C.

Consequently, the procedure can be interpreted as a two-layer verification mechanism $Identity(u) \wedge CredentialValidity(u) \wedge Authority(u, C) \Rightarrow VI(u) = VALID$.

6.5.2 Algorithm 2: DID and VC Identity and Authority Verification

Algorithm 2 formalises the procedure. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns $V_I(u) = VALID$. Otherwise, the procedure terminates at the first failed mandatory verification condition and returns $V_I(u) = INVALID$. The system records the evidence. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, and verification timestamp. This evidence provides an auditable basis for subsequent access-authorisation decisions.

Algorithm 2 DID and VC Identity and Authority Verification

Require: Participant u, consent object C
Ensure: Verification result $V_I(u) \in \{\text{VALID, INVALID}\}$, where VALID corresponds to $V_I(u) = 1$

1: Resolve DID of u
2: **if** DID resolution fails **then**
3: **return** INVALID
4: **end if**
5: Verify DID document and associated identity information
6: **if** DID verification fails **then**
7: **return** INVALID
8: **end if**
9: Retrieve VC associated with u
10: **if** VC retrieval fails **then**
11: **return** INVALID
12: **end if**
13: Verify VC signature, issuer, subject, and validity
14: **if** VC verification fails **then**
15: **return** INVALID
16: **end if**
17: Extract role and authority claims from VC
18: **if** claims do not satisfy the authority requirements of C **then**
19: **return** INVALID
20: **end if**
21: Record identity and authority verification evidence
22: **return** VALID

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance. This mechanism turns identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4 (Chapters 7 and 8).

6.6 Prototype Implementation

6.6.1 Realisation in the Prototype

RO2 has been completed at the conceptual and prototype level. The current implementation demonstrates the separation between participant identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data. Each credential used by the prototype comes from a demo issuer, and the check covers the four conditions of VC_{valid}, namely the signature, issuer, subject and validity time, together with the role claim. The doctor and guardian credentials are checked when the consent is created. Each guardian's credential is checked again before the guardian signs, as Section 6.4 describes, and the doctor's credential is checked again at each access request, where the DID that the doctor enters must also be the doctor named in the consent. V_I in the current prototype combines this doctor check with EIP-712 verification of the signature of each listed guardian, and its outcome is recorded in the audit ledger. A request that fails V_I is refused before any data is released, and the refusal is recorded. An invalid or forged credential is also refused (attack scenario A12). Because the demo issuer key can be rebuilt from the source code, this check shows the verification steps, not the secrecy of the issuer key. The prototype also derives each guardian's signing key from the guardian DID. Full DID resolution against a registry (Algorithm 2, lines 1 to 8), proof that the user controls the DID entered,

and wallet-held keys are acknowledged limitations reserved for the next stage. The validation evidence for RO2, including the scenarios and the unit-level adversarial tests, is presented in Section 6.7.

6.6.2 Steps in the Working of the Prototype for Identity and Authority Verification

In order to verify a participant, the HALAH prototype carries out the following steps at two points of the workflow: when a guardian approves a consent, and when a doctor requests data. The same service functions are called at both points, so the check that the guardian interface applies is the check that the doctor interface applies. The steps involved are as below:

1. Get the DID and its credential: The DID of the participant is taken from the interface, for a guardian from the list of guardians of the consent and for a doctor from the DID entered, and the credential of that DID is read from the credential store.
2. Check the identifier: The DID is checked against the syntax did:method:identifier, and a malformed identifier fails the check.
3. Verify the credential: The four conditions of VC^valid| are evaluated one by one: the signature against the registered address of the issuer, the issuer against the registry, the subject against the DID presented, and the validity period against the clock of the server.
4. Match the role and bind to the consent: The role claim must be guardian for an approval and doctor for a request, and the DID of the doctor must be the authorised doctor named in the consent.
5. Record the evidence and return VI: The credential identifier and the issuer are written to the audit ledger with the approval, and the DID and credential of the requester with every decision. A guardian who fails the check cannot sign, and the refused approval is recorded; a doctor who fails VI is refused before the scope of the consent or any record is shown, and the refused request is recorded.

The logical working of the above steps is shown pictorially in Figure 6.4. Figure 6.5 shows the guardian interface after step 5 for the guardian did:parent:A, with the credential verified and the signature added, and Figure 6.6 shows the doctor interface for a requester who holds a valid doctor credential but is not the doctor named in the consent, where VI fails and the request is refused and recorded.

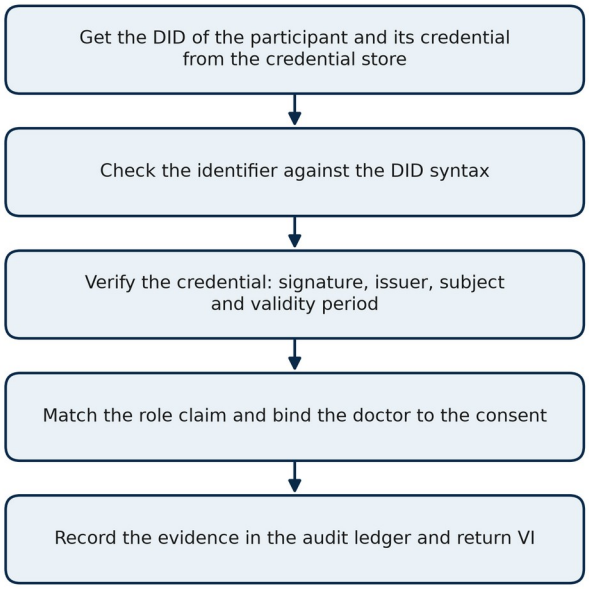


Figure 6.4: Steps of the prototype for verifying the identity and the authority of a participant

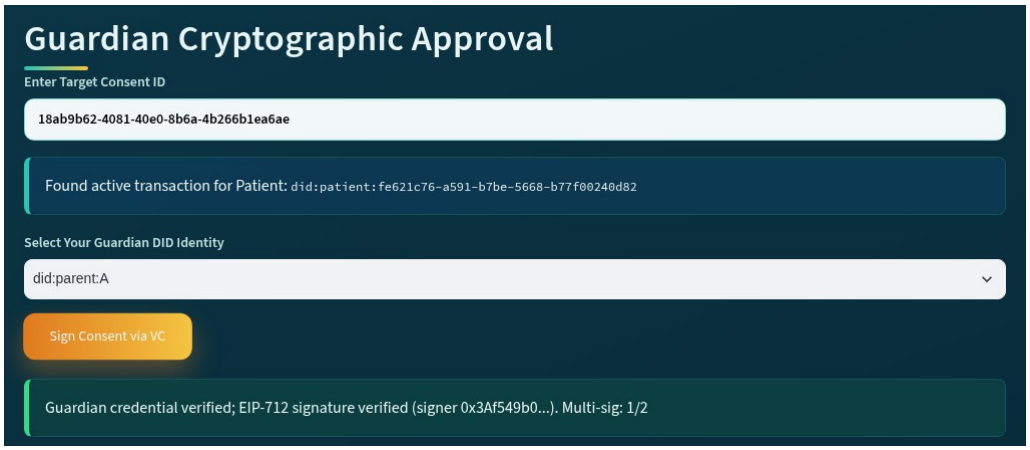


Figure 6.5: Guardian interface after the credential of did:parent:A has been verified and the approval signed

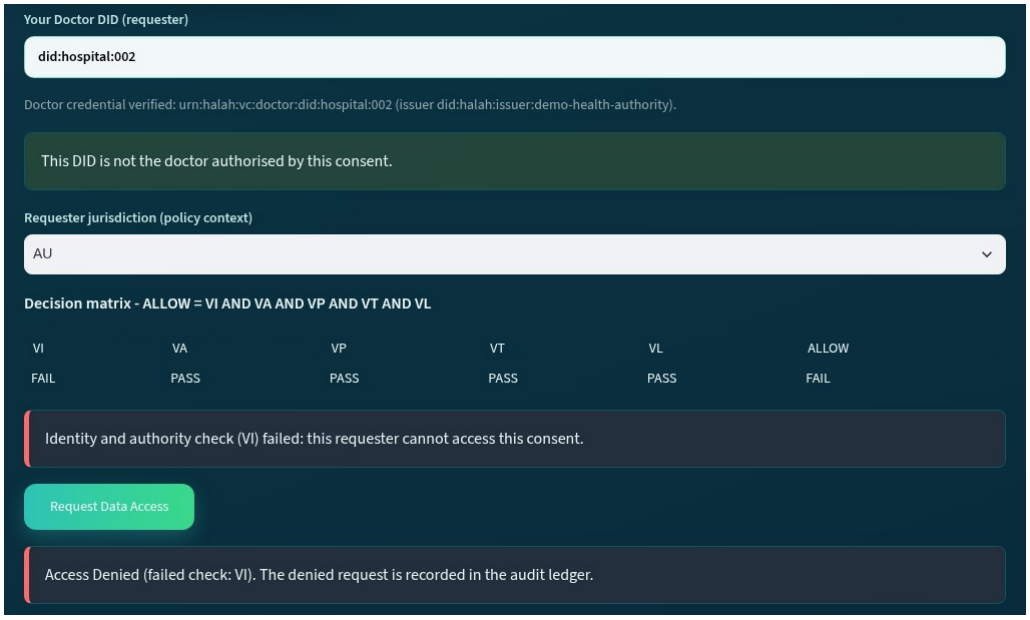


Figure 6.6: Doctor interface for a requester with a valid credential who is not the doctor named in the consent

6.7 Prototype Validation and Discussion

Objective two involves the verification of the identity and the authority of a participant as two separate conditions. The result of RO2 is therefore the verification model of Sections 6.3 to 6.5 and its predicate VI, not a set of measurements. The prototype results reported in this section show that the model can be realised and behaves as specified, so they are reported as outcomes, verified or refused, rather than as numbers; the quantitative evaluation of the complete framework is given in Chapter 10. RO2 is validated in three ways: through the live run of the prototype, through the automated tests of the credential check, and through the adversarial scenario A12, and the results are brought together in Table 6.1.

6.7.1 Validation of Identity and Authority Verification

Live scenario. In the local run of 11 October 2026 on the consent 18ab9b62, whose creation was reported in Chapter 5, the guardian did:parent:A approved at 17:41:45 and the guardian did:parent:B at 17:41:53. Each approval was accepted only after the

guardian credential had been verified, and the ledger row of each approval holds the credential identifier, urn:halah:vc:guardian:did:parent:A and urn:halah:vc:guardian:did:parent:B, and the issuer did:halah:issuer:demo-health-authority (Figure 6.5). A request was then made with the DID did:hospital:002, which holds a valid doctor credential but is not the doctor named in the consent. The decision matrix recorded VI = FAIL with the other four checks passed, and the request was refused at 17:42:04 with the result DENIED and the DID and credential of the requester written to the ledger (Figure 6.6). The same request made with did:hospital:001, the authorised doctor, passed VI at 17:42:19 and was granted at 17:42:21. This is the positive control: the same consent, the same credential store and the same checks, with only the requester changed. At creation, in the same run, a doctor DID without a valid doctor credential and a guardian DID without a valid guardian credential had been rejected before the consent was stored, as reported in Section 5.9.1.

Before and after the credential check. Before the credential check was added on 11 October 2026, the identity check accepted any string that began with did:. A probe of the decision function with three inputs, a doctor DID with no credential, two DIDs typed into one field, and a guardian DID used as the doctor, returned VI = PASS and ALLOW for all three. After the change, the same probe returns VI = FAIL and DENY for all three. The design of Section 6.5 was therefore correct before the change, but its implementation was not, which is the kind of gap that the validation of each objective is meant to find.

Automated tests. Five tests cover the credential check. The test test_demo_credentials_verify_and_are_reproducible asserts that each guardian credential verifies for the role guardian and fails for the role doctor, that each doctor credential verifies for the role doctor and fails for the role guardian, and that a stored credential equals the one the issuer produces for the same DID and role. The test test_each_credential_condition_fails_on_its_own alters one condition at a time, a claim changed after signing, an unknown issuer, the credential of another subject, a check dated after the validity period, the wrong role, and a DID with no credential, and asserts that each condition fails on its own. The test test_did_syntax asserts that nine malformed identifiers are refused. The test test_vi_binds_the_requester_to_the_consent_doctor asserts that a valid doctor who is not the doctor of the consent fails VI, and the test test_credential_time_follows_the_evaluation_time_and_bad_fields_fail_closed asserts that a credential is refused when the evaluation time lies after its validity period and that a malformed credential object is refused rather than accepted. The adversarial scenario A12, invalid or forged credential (test_A13_invalid_or_forged_credential_is_rejected), presents a credential signed by a key that is not the issuer's, a credential from an untrusted issuer, a guardian credential whose role claim was changed to doctor, the credential of another DID and an expired credential, and asserts that each fails VI and gives DENY; it also refuses a guardian posing as the doctor, a valid doctor not named in the consent, and a well-formed DID with no credential. All of these tests pass in the suite of 46 reported in Chapter 10, and the credential check takes about 6 ms per credential, as measured in Chapter 10.

Table 6.1 brings these results together by condition of the verification model. For each condition it gives the step of the procedure and the lines of Algorithm 2 that apply it, the evidence from the live run and the automated tests, and the result observed.

Table 6.1: Validation results of the prototype for identity and authority verification

Condition	Check (procedure step and Algorithm 2 lines)	Evidence	Result
DID syntax	Steps 1 and 2 (Algorithm 2, lines 1 to 8), reduced in this stage to the syntax did:method:identifier.	Test test_did_syntax: nine malformed identifiers refused, among them an empty string, a missing method, an upper-case method and a space inside the identifier. Run of 11 October 2026: two DIDs typed into one field refused (Section 5.9.1).	Malformed identifiers refused; well-formed identifiers pass to the credential check.
Credential found	Step 3 (lines 9 to 12): a credential for the DID must exist in the credential store.	A well-formed DID with no credential, did:hospital:999, fails VI (tests test_each_credential_condition_fails_on_its_own and A12).	No credential, no participation.
Signature	Step 4 (lines 13 to 16): the signature must recover to the registered address of the issuer.	A claim changed after signing (validUntil moved to 2099) fails the signature condition; a credential signed by a key that is not the issuer's is refused (A12).	Tampered and forged credentials refused.
Issuer	Step 4: the issuer must be in the trusted-issuer registry.	A credential from did:example:other and one from an unknown issuer fail the issuer condition (tests and A12).	Untrusted issuers refused.
Subject	Step 4: the subject of the credential must be the DID presented.	The credential of did:hospital:002 presented for did:hospital:001 fails the subject condition (tests and A12).	A credential cannot be borrowed by another DID.
Validity period	Step 4: the time of the check must lie between validFrom and validUntil.	A check dated 1 January 2031, after the validUntil of the demo credentials, fails; an expired credential is refused (A12); the check follows the evaluation time passed to the decision function.	Expired credentials refused.
Role	Steps 5 and 6 (lines 17 to 20): the role claim must be the role the step requires.	A guardian credential presented as a doctor fails the role condition; a guardian posing as the doctor is refused (A12). Each guardian credential verifies as guardian and fails as doctor, and each doctor credential the reverse.	Wrong role refused.
Binding to the consent	Steps 6 and 7: the doctor must be the authorised doctor named in the consent.	Run of 11 October 2026: did:hospital:002 holds a valid doctor credential but is not the doctor of consent 18ab9b62; VI = FAIL, request DENIED at 17:42:04 (Figure 6.6). Test test_vi_binds_the_requester_to_the_consent_doctor.	A valid doctor is refused on a consent that does not name them; did:hospital:001 passed VI at 17:42:19.
Evidence	Step 8 (line 21): the verification evidence is recorded.	Ledger rows of the approvals at 17:41:45 and 17:41:53 carry the credential identifier and the issuer; the STATE_CHECK and DATA_ACCESS rows of 17:42:04 and 17:42:19 carry the requester DID and its credential.	Every approval and every decision is traceable to a credential.

6.7.2 Discussion

The use of decentralised identifiers and verifiable credentials for identity and authority verification has several advantages which include separation, evidence, and independence from a central identity provider. Separation means that the identity of a participant and the authority of that participant are two checks, so a valid identity never gives access by itself, and a credential never gives access to a consent that does not name its holder. Evidence means that every approval and every decision carries the credential

identifier and the issuer, so an auditor can see on whose authority a guardian signed or a doctor was refused. Independence means that the verifier needs only the registered address of the issuer and not a connection to it, so a credential issued by one healthcare authority can be checked by any HALAH instance that trusts that authority.

On the other hand, the trade-offs are the dependence on the issuer and the limits of this stage. A credential is only as trustworthy as its issuer, and the current check has no credential revocation list, so a credential withdrawn by its issuer remains valid until its validUntil time. The DID is checked for its syntax and not resolved, and the DID of the requester is entered rather than authenticated, so VI shows that the DID entered holds a valid doctor credential and is the doctor named in the consent, not that the person at the interface controls that DID. Although these may be considered limitations of the method, the certainty that no participant takes part without a credential of the right role from a trusted issuer outweighs them at this stage, and DID resolution, holder binding and wallet-held keys are addressed in the next stage of the research, as discussed in Chapter 11.

6.8 Conclusion

In this chapter, we discussed decentralised identifiers and verifiable credentials and used them to verify who a participant is and what authority the participant holds as two separate conditions. In particular, we presented the principle that identity is not authorisation, the verification condition $\mathrm{VI}(u) = \mathrm{VerifyDID}(u) \wedge \mathrm{VerifyVC}(u) \wedge \mathrm{Authority}(u, C)$, the nine-step verification procedure and Algorithm 2, in which a credential is valid only when its signature, issuer, subject and validity period are all verified and its role claim matches the role that the consent requires. This addressed the second research objective of this thesis.

In this chapter we also presented the realisation of the verification in the HALAH prototype and the results of its validation. At the end of the validation process, the results show that a guardian signs only after the guardian credential has been verified, that a doctor who holds a valid credential but is not the doctor named in the consent is refused before any record is shown, and that forged, tampered, expired, untrusted and misdirected credentials are refused one condition at a time. However, a key finding from the validation was that the prototype verifies the credential of the DID entered, not that the user controls that DID; holder binding and DID resolution are the work of the next stage.

The next chapter will discuss in a methodological manner the steps involved in the multi-party approval of the consent by the guardian set, which is the solution for research objective 3.